



RÉPUBLIQUE ISLAMIQUE DE LA MAURITANIE
MINISTÈRE DE L'ENSEIGNEMENT SUPÉRIEUR ET DE LA
RECHERCHE SCIENTIFIQUE



UNIVERSITÉ DE NOUAKCHOTT
FACULTÉ DES SCIENCES ET TECHNIQUES
DÉPARTEMENT D'INFORMATIQUE



كلية العلوم و التقنيات
FACULTÉ DES SCIENCES ET TECHNIQUES

MÉMOIRE DE FIN D'ÉTUDES

*En vue de l'obtention de la Licence en Développement, Administration Intranet
et Internet (DAII)*

Sujet :

Mise en place
d'un environnement virtuel de sécurité basé
sur IDS/IPS avec Suricata et pfSense

Encadré par :

Présenté par :

Mohamed Salem Abdel Wedoud

Prof. Ahmed Mohamed Lemine

Mamoune

Expert Chef Service de Sécurité :

Mr. Moulaye Ahmed Dahane

Membres du Jury :

Membre :

Dr. El Veth Sidi

Membre :

Dr. Cheikh Abdelkader Telmoud

Membre :

Pr. Beide Bouh Cheikhne

Encadrant Pédagogique :

Pr. Ahmed Mohamed Lemine Mamoune

Année universitaire : 2025 – 2026

Dédicaces

Je dédie ce modeste travail :

*À mes chers parents,
Source intarissable d'amour, de tendresse et de sacrifices,
Pour leurs prières quotidiennes, leur patience inépuisable
et leur soutien indéfectible tout au long de mon parcours.
Aucun mot ne saurait exprimer ma profonde reconnaissance.*

*À mes frères et sœurs,
Pour leur affection sincère, leurs encouragements constants
et leur présence chaleureuse à chaque étape de ma vie.*

*À toute ma famille,
Pour son amour et son soutien moral inconditionnel.*

*À mes professeurs,
Qui ont su me transmettre, avec rigueur et passion,
le savoir et les valeurs nécessaires à ma formation.*

*À mes amis et camarades,
Avec qui j'ai partagé d'innombrables moments d'études,
de doutes et de réussites.*

*À tous ceux qui, de près ou de loin, ont contribué
à la réalisation de ce travail.*

Je vous dédie ce modeste travail.

Mohamed Salem Abdel Wedoud

Remerciements

Au terme de ce travail, je tiens à exprimer ma profonde gratitude à toutes les personnes qui ont contribué, de près ou de loin, à la réussite de ce projet de fin d'études.

Je tiens tout d'abord à exprimer ma profonde gratitude à mes parents pour leur soutien inconditionnel, leurs encouragements constants et les sacrifices qu'ils ont consentis tout au long de mon parcours académique. Leur confiance, leur patience et leurs conseils ont été une source de motivation essentielle pour mener à bien ce travail. Je tiens à exprimer ma sincère reconnaissance à mon encadrant pédagogique, **Prof. Ahmed Mohamed Lemine Mamoune**, enseignant à la Faculté des Sciences et Techniques de l'Université de Nouakchott, pour son suivi rigoureux, ses conseils précieux, sa disponibilité et la qualité de son encadrement tout au long de la réalisation de ce projet.

Mes remerciements les plus chaleureux vont également à mon encadrant professionnel à la **Banque Nationale Mauritanienne**, **Expert et Chef Service de Sécurité : Mr. Moulaye Ahmed Dahane**, pour la confiance qu'il m'a accordée, son accompagnement quotidien, son expertise dans le domaine de la cybersécurité bancaire et ses retours constructifs qui ont considérablement enrichi la qualité de ce travail.

Je remercie également l'ensemble du **personnel de la Direction des Systèmes d'Information (DSI)** de la BNM, notamment l'équipe sécurité et l'équipe réseaux, pour leur accueil chaleureux, leur disponibilité et le partage de leur expérience professionnelle durant toute la période de mon stage.

Je tiens à exprimer ma profonde gratitude à **Dr. El Benany Med Mahmoud**, coordinateur de la filière DAI, pour son rôle déterminant dans l'organisation et le suivi de notre formation.

Je remercie vivement les **membres du jury** qui ont accepté d'évaluer ce travail, ainsi que l'ensemble du **corps enseignant et administratif** de la Faculté des Sciences et Techniques pour la qualité de la formation dispensée tout au long de mon cursus.

Une pensée toute particulière est adressée à mes **chers parents**, dont l'amour, les prières et le soutien moral ont été le socle de ma motivation et de ma persévérance.

Enfin, je remercie chaleureusement ma **famille**, mes **amis** et tous mes **collègues étudiants** pour leurs encouragements et leur présence à mes côtés.

Que toutes et tous trouvent ici l'expression de ma sincère reconnaissance.

Résumé

Le présent rapport a été élaboré dans le cadre d'un projet de fin d'études réalisé au sein de la **Banque Nationale de Mauritanie**, en vue de l'obtention de la Licence Professionnelle en **Développement, Administration Intranet et Internet** à la Faculté des Sciences et Techniques de l'Université de Nouakchott.

Face à la recrudescence des cyberattaques visant les institutions financières, la mise en place de mécanismes de surveillance réseau est devenue une exigence stratégique. Ce projet répond à la problématique suivante : **comment concevoir et tester une infrastructure de sécurité réseau capable de détecter et de bloquer les intrusions visant un système d'information bancaire, sans mobiliser un équipement matériel coûteux ?**

Pour répondre à cette problématique, la solution proposée repose sur une infrastructure de sécurité basée sur les technologies **IDS/IPS** (*Intrusion Detection System / Intrusion Prevention System*), mise en œuvre à l'aide de **Suricata**, moteur open source intégré au pare-feu **pfSense**. L'objectif principal est de protéger le système d'information bancaire contre les intrusions, les attaques par force brute, les scans de ports et les tentatives d'exploitation de vulnérabilités.

L'ensemble du projet a été conçu dans un **environnement entièrement virtualisé** sous **Oracle VirtualBox**. Ce choix de la virtualisation a été retenu pour trois raisons principales : il permet de **simuler fidèlement une architecture réseau bancaire réelle** (pare-feu, contrôleur de domaine Active Directory, serveur FTP, postes clients Windows et Linux, et tunnel OpenVPN sécurisé), tout en assurant une **réduction significative des coûts matériels**; il offre en outre un **environnement de test isolé et reproductible**, dans lequel les attaques peuvent être menées sans risque pour un système en production.

Les tests d'intrusion, menés depuis une machine **Kali Linux**, ont validé l'efficacité du système : l'ensemble des scans Nmap (SYN, XMAS, FIN, NULL), les attaques par force brute Hydra sur le service FTP, ainsi que les tentatives d'exploitation ont été détectés et classifiés en temps réel par Suricata, s'appuyant sur plus de milliers de signatures Emerging Threats. Les résultats obtenus confirment qu'une solution de sécurité performante et économique peut être déployée et éprouvée dans un cadre virtualisé avant tout passage en production.

Abstract

This report was prepared as part of a final-year project carried out at the **National Bank of Mauritania**, in fulfillment of the requirements for the Professional Bachelor's Degree in **Development, Intranet and Internet Administration** at the Faculty of Sciences and Techniques of the University of Nouakchott.

In a context where financial institutions face an unprecedented surge in cyberattacks, the implementation of effective network monitoring mechanisms has become a strategic necessity. This project addresses the following research question : **how can a network security infrastructure be designed and tested to detect and block intrusions targeting a banking information system, without requiring costly physical hardware ?**

To address this question, the proposed solution relies on a security infrastructure based on **IDS/IPS** (*Intrusion Detection System / Intrusion Prevention System*) technologies, implemented using **Suricata**, an open-source engine integrated into the **pfSense** firewall. The main objective is to protect the banking information system against intrusions, brute-force attacks, port scans, and vulnerability exploitation attempts.

The entire project was designed within a **fully virtualized environment** using **Oracle VirtualBox**. This choice of virtualization was made for three main reasons : it allows for the **faithful simulation of a real banking network architecture** (firewall, Active Directory domain controller, FTP server, Windows and Linux client workstations, and a secure OpenVPN tunnel), while ensuring a **significant reduction in hardware costs**; it also provides an **isolated and reproducible testing environment** in which attacks can be conducted without any risk to a production system. This approach thus makes it possible to simulate a real network architecture while overcoming the constraints associated with acquiring physical equipment.

The penetration tests, conducted from a **Kali Linux** machine, validated the effectiveness of the system : all Nmap scans (SYN, XMAS, FIN, NULL), Hydra brute-force attacks on the FTP service, as well as exploitation attempts, were detected and classified in real time by Suricata, relying on more than 30,000 Emerging Threats signatures. The results obtained confirm that an effective and cost-efficient security solution can be deployed and tested within a virtualized environment prior to any production deployment.

Table des matières

Dédicaces	2
Remerciements	3
Résumé	4
Abstract	5
Table des matières	8
Liste des figures	9
Liste des tableaux	10
Liste des abréviations	11
Introduction Générale	12
1 Présentation de l'Organisme d'Accueil : Banque Nationale de Mauritanie	14
1.1 Présentation générale	14
1.2 Enjeux de la cybersécurité dans le secteur bancaire	15
1.3 Cadre du stage	15
1.4 Mission assignée	15
2 Étude Théorique : IDS/IPS et Sécurité Réseau	16
2.1 Notions fondamentales de sécurité réseau	16
2.1.1 Le modèle CIA	16
2.1.2 Le pare-feu (Firewall)	16
2.2 Les systèmes IDS et IPS	17
2.2.1 Définition et différences	17
2.2.2 Méthodes de détection	17
2.2.3 Suricata : présentation	17
2.2.4 Les règles Suricata : format GID :SID	18
2.3 OpenVPN et sécurité des accès distants	18
2.4 Active Directory et gestion des identités	18
3 Conception et Architecture du Laboratoire	19
3.1 Choix de l'environnement de virtualisation	19
3.2 Architecture réseau générale	19
3.2.1 Schéma de l'architecture	19
3.2.2 Plan d'adressage IP	20
3.3 Ressources allouées aux machines virtuelles	20
3.4 Domaine Active Directory	20

4	Mise en Œuvre de l'Infrastructure.....	21
4.1	pfSense — Pare-feu et Routeur	21
4.1.1	Installation et configuration	21
4.1.2	Problème de routage résolu	21
4.2	Active Directory — Domaine monlab.local	22
4.2.1	SRV-AD1 : Contrôleur de domaine principal	22
4.2.2	SRV-AD2 : Contrôleur de domaine secondaire	22
4.2.3	Comptes utilisateurs créés	23
4.3	Postes clients	23
4.3.1	W-CLIENT (Windows 10)	23
4.3.2	Debian (Debian 12 Bookworm)	24
4.4	VPN OpenVPN	25
4.4.1	Définition	25
4.4.2	Principes de fonctionnement	25
4.4.3	Configuration du serveur	26
4.4.4	Tests de connexion	26
4.4.5	L'accès au partage par openVPN	27
5	Déploiement et Configuration de Suricata IDS/IPS	28
5.1	Installation de Suricata sur pfSense	28
5.2	Configuration générale	28
5.2.1	Paramètres principaux	28
5.3	Règles Emerging Threats	29
5.3.1	Téléchargement des règles	29
5.3.2	Catégories de règles activées	30
5.4	Modes de fonctionnement	30
5.4.1	Mode IDS (Détection seule)	30
5.4.2	Mode IPS (Prévention active)	30
5.5	Statut Suricata	31
6	Tests d'Intrusion et Analyse des Résultats.....	32
6.1	Environnement de test	32
6.2	Outils d'attaque utilisés	32
6.3	Scénarios d'attaque et résultats	33
6.3.1	Test sur LAN :	33
6.3.2	Test sur WAN :	37
6.4	Tableau récapitulatif des tests	39
6.5	Système de priorités des alertes	39
6.6	Analyse et interprétation	40
6.6.1	Efficacité du système	40
6.6.2	Gestion des faux positifs	40
7	Immersion en Production : Compléments de sécurité XDR (ESET) ..	41
7.1	Présentation générale de la solution ESET XDR	41
7.2	Mécanismes de détection et de protection	42

7.2.1	Détection des intrusions et des menaces	42
7.2.2	Blocage automatique des menaces	42
7.2.3	Système d’alertes en temps réel	42
7.2.4	Isolation des machines compromises	42
7.3	Déploiement de l’agent ESET sur le parc bancaire	43
7.3.1	Préparation et installation du package	43
7.3.2	Initialisation et activation de la protection	44
7.3.3	Analyse initiale et vérification du poste	46
7.3.4	Gestion des règles du pare-feu local	46
7.3.5	Dépannage de l’accès réseau	47
7.3.6	Résolution de problèmes annexes	47
7.4	Console ESET PROTECT : supervision centralisée du parc	47
7.4.1	Tableau de bord et statistiques globales	47
7.4.2	Vue détaillée d’un poste supervisé	48
7.4.3	Notifications automatiques par courriel	49
7.5	Bilan de cette immersion	49
	Conclusion Générale.....	50
A	Checklist Complète du Projet	52
B	Problèmes Rencontrés et Solutions.....	53
C	Technologies Utilisées.....	54
D	Attestation et Profile.....	56

Table des figures

2.1	Le modèle CIA	16
3.1	Architecture réseau du laboratoire	19
5.1	Flux de traitement du trafic par Suricata en mode IPS	30
7.1	Package Installer ESET : sélection des composants et rattachement à la licence BNM	43
7.2	Confirmation de l'installation réussie des trois composants ESET	44
7.3	Invite de redémarrage du poste après installation des composants	44
7.4	Phase d'initialisation de la protection après installation	45
7.5	Poste protégé et modules à jour après initialisation	45
7.6	Lancement de l'analyse initiale du poste	46
7.7	Console de gestion des règles du pare-feu local ESET	46
7.8	Interface de dépannage de l'accès réseau et déblocage d'applications	47
7.9	Tableau de bord ESET PROTECT : vue ESET Inspect et statistiques de détection	48
7.10	Fiche détaillée d'un poste supervisé depuis la console ESET PROTECT	48
7.11	Notification automatique reçue lors du raccordement d'un nouveau poste au parc	49

Liste des tableaux

2.1	Comparaison IDS et IPS	17
2.2	Structure des identifiants de règles Suricata	18
3.1	Plan d'adressage du réseau de laboratoire	20
3.2	Dimensionnement des machines virtuelles	20
4.1	Comptes utilisateurs Active Directory	23
4.2	Paramètres de configuration OpenVPN	26
5.1	Catégories de règles Suricata activées	30
6.1	Outils de tests d'intrusion	32
6.2	Résultats complets des tests d'intrusion	39
6.3	Niveaux de priorité des alertes Suricata	39
A.1	État d'avancement du projet	52
B.1	Problèmes et solutions	53
C.1	Stack technologique du projet	54

Liste des abréviations

AD	Active Directory
AD DS	Active Directory Domain Services
AES	Advanced Encryption Standard
BNM	Banque Nationale de Mauritanie
CIA	Confidentiality, Integrity, Availability
DAII	Développement, Administration Intranet et Internet
DDoS	Distributed Denial of Service
DHCP	Dynamic Host Configuration Protocol
DNS	Domain Name System
DSI	Direction des Systèmes d'Information
ET	Emerging Threats
EVE	Extensible Event Format
FTP	File Transfer Protocol
GID	Generator Identifier
GPO	Group Policy Object
GSO	Generic Segmentation Offload
HTTPS	Hypertext Transfer Protocol Secure
IDS	Intrusion Detection System
IIS	Internet Information Services
IP	Internet Protocol
IPS	Intrusion Prevention System
LAN	Local Area Network
NAT	Network Address Translation
NGFW	Next-Generation Firewall
NSE	Nmap Scripting Engine
NTP	Network Time Protocol
PCI-DSS	Payment Card Industry Data Security Standard
SID	Signature Identifier
SIEM	Security Information and Event Management
SOAR	Security Orchestration, Automation and Response
SSH	Secure Shell
SSL	Secure Sockets Layer
TCP	Transmission Control Protocol
TLS	Transport Layer Security
UDP	User Datagram Protocol
VPN	Virtual Private Network
WAN	Wide Area Network
XDR	Extended Detection and Response

Introduction Générale

Contexte

Dans un monde de plus en plus connecté, la cybersécurité est devenue un enjeu stratégique majeur pour les institutions financières. Les banques, en tant que dépositaires de données sensibles et de fonds de leurs clients, constituent des cibles privilégiées pour les cybercriminels. La **BNM**, comme l'ensemble du secteur financier mauritanien, doit faire face à des menaces croissantes : attaques par déni de service, intrusions sur les réseaux internes, tentatives de vol de données et accès non autorisés.

Problématique

Face à l'augmentation des cybermenaces visant les institutions financières, comment une infrastructure bancaire simulée dans un environnement VirtualBox peut-elle être sécurisée à l'aide de Suricata et pfSense afin d'assurer une détection et une prévention efficaces des intrusions en temps réel, tout en garantissant la disponibilité des services et la limitation des faux positifs ?

Objectifs du projet

Ce projet de fin d'études vise à :

- Concevoir et déployer une architecture réseau sécurisée reproduisant l'environnement réel de la BNM.
- Déployer l'ensemble de l'infrastructure dans un environnement virtualisé à l'aide de VirtualBox afin de simuler une architecture bancaire réelle.
- Installer, configurer et intégrer un système **IDS/IPS** basé sur **Suricata** avec le pare-feu **pfSense** pour assurer la détection et la prévention des intrusions.
- Mettre en œuvre un tunnel VPN sécurisé avec **OpenVPN** pour l'accès distant.
- Effectuer des tests d'intrusion réalistes afin d'évaluer l'efficacité des mécanismes de sécurité .
- Analyser et interpréter les alertes générées afin de proposer des recommandations pour renforcer la sécurité du réseau bancaire.
- Contribuer à la réduction des risques d'attaques et renforcer la disponibilité, l'intégrité et la confidentialité des services et des données bancaires.

*“La sécurité n'est pas un produit,
c'est un processus.”*

— Bruce Schneier

Structure du rapport

Ce rapport est organisé en six chapitres :

- **Chapitre 1** : Présentation de l'organisme d'accueil (Banque Nationale de Mauritanie) et du cadre du stage.
- **Chapitre 2** : Étude théorique des technologies IDS/IPS et de l'écosystème de sécurité réseau.
- **Chapitre 3** : Conception et architecture du laboratoire réseau.
- **Chapitre 4** : Mise en œuvre de l'infrastructure (pfSense, Active Directory, VPN).
- **Chapitre 5** : Déploiement et configuration de Suricata IDS/IPS.
- **Chapitre 6** : Tests d'intrusion, résultats et analyse des alertes.
- **Chapitre 7** : Immersion en production — solution XDR ESET déployée à la BNM.

Chapitre 1

Présentation de l'Organisme d'Accueil : Banque Nationale de Mauritanie

1.1 Présentation générale

La **BNM** est un établissement financier mauritanien créée en 1989 lors d'une fusion entre deux des plus grandes Banques de l'époque (BIMA et SMB), la BNM dispose d'un capital entièrement privé qui se chiffre à 6 milliards d'ouguiya. Dès 1991, sa vision est celle d'une Banque Nationale, accessible à tous, impliquée dans le développement économique avec une forte présence dans les principales villes du pays. Depuis lors la BNM a mis en œuvre une stratégie de développement de son portefeuille auprès de la clientèle corporate pour s'étendre aux professionnels, aux particuliers, aux entreprises et à la diaspora. En quelques années, elle est devenue un acteur majeur du paysage bancaire mauritanien avec une activité centrée sur la proximité à la fois géographique et commerciale. En tant qu'institution financière, elle assure des services bancaires variés à ses clients : particuliers, entreprises et institutions publiques. La sécurité de son système d'information constitue un pilier fondamental de sa stratégie opérationnelle.

Fiche d'identité de la BNM

Nom :	Banque Nationale de Mauritanie
Secteur :	Secteur bancaire et financier
Pays :	Mauritanie
Services :	Banque de détail, entreprises, financement
Direction d'accueil :	Direction des Systèmes d'Information (DSI)
Durée du stage :	1 mois

1.2 Enjeux de la cybersécurité dans le secteur bancaire

Les établissements bancaires traitent quotidiennement des milliers de transactions financières et stockent des données personnelles et financières hautement sensibles. Cette réalité en fait des cibles de choix pour les cybercriminels, qui cherchent à :

- **Voler des données** financières et personnelles des clients.
- **Perturber les services** via des attaques par déni de service (DoS/DDoS).
- **Pénétrer le réseau interne** pour effectuer des mouvements latéraux.
- **Usurper des identités** via du phishing ou de la force brute.

Face à ces menaces croissantes, les institutions bancaires doivent renforcer leurs mécanismes de surveillance, de détection et de réponse aux incidents de sécurité. Cela implique la mise en place de solutions de cybersécurité avancées, telles que les pare-feu, les systèmes de détection et de prévention d'intrusion (IDS/IPS), le chiffrement des données, ainsi que l'authentification multifactorielle. De plus, une surveillance continue du réseau et la sensibilisation des employés aux risques cybernétiques sont essentielles pour prévenir les attaques et garantir la confidentialité, l'intégrité et la disponibilité des données et des services bancaires.

1.3 Cadre du stage

Dans ce contexte, la BNM a sollicité la mise en place d'un **système de détection et de prévention des intrusions** (IDS/IPS) pour renforcer la surveillance de son réseau informatique. Ce projet s'inscrit dans la politique de sécurité globale de la banque, visant à assurer la **confidentialité**, l'**intégrité** et la **disponibilité** (trilogie CIA) de ses systèmes d'information.

L'infrastructure a été déployée dans un environnement virtualisé permettant de simuler une architecture réseau bancaire réelle, tout en offrant un cadre sécurisé pour l'expérimentation et les tests d'intrusion.

1.4 Mission assignée

Mission du stagiaire

Concevoir, déployer et valider une infrastructure de sécurité réseau intégrant un système IDS/IPS Suricata sur pfSense, dans un environnement virtualisé reproduisant l'architecture réelle de la BNM, puis réaliser des tests d'intrusion pour valider l'efficacité de la solution.

Chapitre 2

Étude Théorique : IDS/IPS et Sécurité Réseau

2.1 Notions fondamentales de sécurité réseau

2.1.1 Le modèle CIA

La sécurité des systèmes d'information repose sur trois piliers fondamentaux, communément désignés par l'acronyme **CIA** :

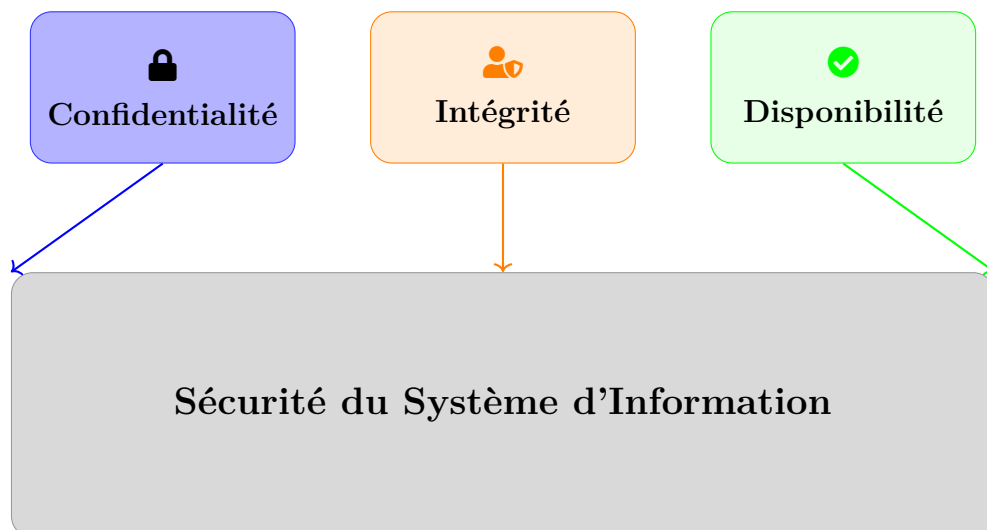


FIGURE 2.1 – Le modèle CIA

2.1.2 Le pare-feu (Firewall)

Un **pare-feu** est un dispositif de sécurité réseau qui contrôle le trafic entrant et sortant selon des règles prédéfinies. Il constitue la première ligne de défense du réseau. **pfSense**, utilisé dans ce projet, est un pare-feu open source basé sur FreeBSD, offrant des fonctionnalités avancées de routage, NAT, VPN et IDS/IPS.

2.2 Les systèmes IDS et IPS

2.2.1 Définition et différences

TABLE 2.1 – Comparaison IDS et IPS

Critère	IDS — Intrusion Detection System	IPS — Intrusion Prevention System
Rôle	Détecter et alerter	Détecter ET bloquer
Mode	Passif (hors bande)	Actif (en ligne)
Action	Génère des alertes	Bloque le trafic malveillant
Impact réseau	Nul	Léger (latence minime)
Risque faux positif	Alerte sans impact	Peut bloquer trafic légitime

2.2.2 Méthodes de détection

Les systèmes IDS/IPS utilisent principalement deux méthodes de détection :

- 🔍 **Détection par signatures (Signature-Based)** : compare le trafic réseau à une base de données de signatures d'attaques connues. Très efficace pour les attaques répertoriées, mais incapable de détecter les nouvelles menaces (*zero-day*).
- 📊 **Détection par anomalies (Anomaly-Based)** : établit un profil de comportement normal du réseau et alerte sur toute déviation significative. Peut détecter les nouvelles attaques mais génère plus de faux positifs.

2.2.3 Suricata : présentation

Suricata est un moteur IDS/IPS open source développé par l'*Open Information Security Foundation* (OISF). Il se distingue par :



Caractéristiques de Suricata

- **Multi-threading** : exploite tous les cœurs CPU pour une analyse haute performance
- **Analyse en profondeur** : inspection jusqu'à la couche applicative (HTTP, FTP, DNS, TLS...)
- **Compatibilité Snort** : accepte les règles au format Snort
- **Emerging Threats** : base de plus de 30 000 signatures actualisées
- **EVE JSON** : journalisation structurée pour intégration SIEM
- **Intégration pfSense** : disponible en tant que package natif

2.2.4 Les règles Suricata : format GID :SID

Chaque règle Suricata est identifiée par un couple unique **GID :SID** :

TABLE 2.2 – Structure des identifiants de règles Suricata

Identifiant	Signification	Description
GID 1	Generator ID 1	Règles standard (signatures texte)
GID 2	Generator ID 2	Règles intégrées au moteur
GID 3	Generator ID 3	Règles de décodage de paquets
SID	Signature ID	Numéro unique identifiant l'attaque

Exemple : **1:2024364** correspond à la signature *“ET SCAN Possible Nmap User-Agent Observed”*.

2.3 OpenVPN et sécurité des accès distants

OpenVPN est une solution VPN open source utilisant le protocole SSL/TLS. Dans le contexte bancaire, il permet aux employés distants d'accéder de manière sécurisée aux ressources internes via un tunnel chiffré, protégé par :

- **Chiffrement AES-256-GCM** : standard militaire de chiffrement symétrique
- **Intégrité SHA256** : garantit l'intégrité des données transmises
- **Double authentification** : certificat X.509 + identifiants utilisateur
- **Diffie-Hellman 2048 bits** : échange de clés sécurisé

2.4 Active Directory et gestion des identités

Active Directory (AD) est le service d'annuaire de Microsoft permettant la gestion centralisée des utilisateurs, des ordinateurs et des politiques de sécurité. Dans un environnement bancaire, il est essentiel pour :

- Le contrôle des accès basé sur les rôles (RBAC)
- L'authentification centralisée (Kerberos)
- L'application des politiques de sécurité (GPO)

Chapitre 3

Conception et Architecture du Laboratoire

3.1 Choix de l'environnement de virtualisation

Pour reproduire l'infrastructure réseau de la BNM sans risque pour la production, nous avons choisi un environnement entièrement virtualisé sous **Oracle VirtualBox 7.1.6**. Ce choix est justifié par :

- La gratuité et la maturité de la solution
- La possibilité de créer des réseaux internes isolés (*intnet*)
- La facilité de snapshots et de restauration
- La compatibilité avec Windows Server, FreeBSD et Linux

3.2 Architecture réseau générale

3.2.1 Schéma de l'architecture

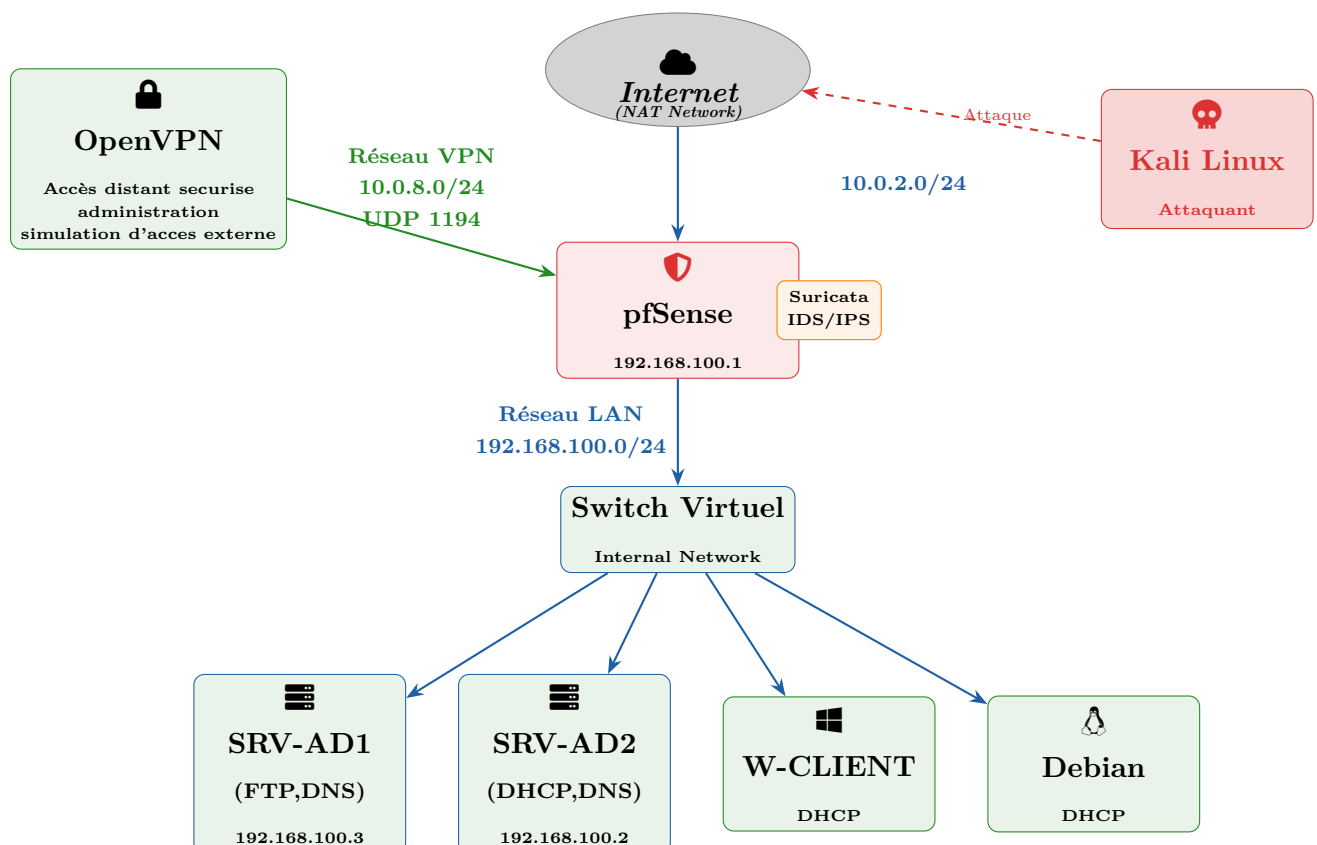


FIGURE 3.1 – Architecture réseau du laboratoire

3.2.2 Plan d'adressage IP

TABLE 3.1 – Plan d'adressage du réseau de laboratoire

Machine	Rôle	Adresse IP	Système d'exploitation
pfSense	Firewall / Routeur / NAT / VPN / IDS-IPS	LAN : 192.168.100.1 WAN : DHCP (NAT)	FreeBSD (pfSense CE 2.8.1)
SRV-AD1	Contrôleur de do- maine principal DNS + FTP	192.168.100.3	Windows Server 2019
SRV-AD2	Contrôleur de do- maine secondaire DHCP	192.168.100.2	Windows Server 2019
W-CLIENT	Poste client, joint au domaine	192.168.100.5 (DHCP)	Windows 10
Debian	Poste client, joint au domaine	192.168.100.4 (DHCP)	Debian 12 (Book- worm)
Kali Linux	Machine d'attaque (tests)	LAN ou NAT	Kali Linux

3.3 Ressources allouées aux machines virtuelles

TABLE 3.2 – Dimensionnement des machines virtuelles

VM	RAM	Disque	Cartes réseau
pfSense	1 024 Mo	8 Go	NAT (WAN) + Réseau interne (LAN)
SRV-AD1	3 Go	40 Go	Réseau interne (intnet)
SRV-AD2	3 Go	40 Go	Réseau interne (intnet)
W-CLIENT	2 Go	40 Go	Réseau interne (intnet)
Debian	4 Go	20 Go	Réseau interne (intnet)
Kali Linux	2 Go	20 Go	Interne ou NAT
Total alloué : ≈ 15 Go / 16 Go (hôte)			

3.4 Domaine Active Directory

Le domaine Active Directory déployé est **monlab.local**, représentant le domaine interne de la BNM. Il repose sur une architecture à deux contrôleurs pour la haute disponibilité et la redondance.

Chapitre 4

Mise en Œuvre de l'Infrastructure

4.1 pfSense — Pare-feu et Routeur

4.1.1 Installation et configuration

pfSense CE (Community Edition) a été installé sur VirtualBox avec deux interfaces réseau :

- **em0 (WAN)** : connectée en NAT VirtualBox pour l'accès Internet
- **em1 (LAN)** : IP fixe [192.168.100.1/24](#), réseau interne

Configuration pfSense

```

1 Interface WAN (em0)      :   DHCP (via NAT VirtualBox -
    10.0.2.4)
2 Interface LAN (em1)     :   192.168.100.1/24
3 DNS Resolver           :   Mode Forwarding
4 Forwarders DNS         :   8.8.8.8, 1.1.1.1
5 Default Gateway        :   WAN_DHCP (10.0.2.2 via em0)
6 NAT                    :   Automatique (toutes machines LAN ->
    Internet)
7 Interface web           :   https://192.168.100.1

```

```

FreeBSD/amd64 (pfSense.monlab.lan) (ttyv0)
VirtualBox Virtual Machine - Netgate Device ID: 46f9198dcd12bc2cce51
*** Welcome to pfSense 2.8.1-RELEASE (amd64) on pfSense ***

WAN (wan) -> em0 -> v4/DHCP4: 10.0.2.4/24
LAN (lan) -> em1 -> v4: 192.168.100.1/24

```

4.1.2 Problème de routage résolu

❗ Problème critique : Boucle de routage

Symptôme : TTL Expired — les paquets bouclaient indéfiniment.

Cause : La gateway LAN (*LANGW*) était définie comme route par défaut au lieu de la gateway WAN.

Solution : Suppression de *LANGW* comme route par défaut ; `Default gateway = WAN_DHCP`.

4.2 Active Directory — Domaine monlab.local

4.2.1 SRV-AD1 : Contrôleur de domaine principal

SRV-AD1 héberge les rôles essentiels du domaine :

- **AD DS** : création de la forêt Active Directory monlab.local
- **DNS Server** : résolution de noms interne, forwarders vers pfSense et 8.8.8.8
- **IIS FTP Server** : site FTP-MonLab sur le port 21, authentification AD

```
Ethernet adapter Ethernet:

Connection-specific DNS Suffix . : monlab.local
Link-local IPv6 Address . . . . . : fe80::a5a1:5da8:32e9:31c0%3
IPv4 Address. . . . . : 192.168.100.3
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 192.168.100.1
```

4.2.2 SRV-AD2 : Contrôleur de domaine secondaire

- **AD DS (réplica)** : réplication automatique depuis SRV-AD1
- **DHCP Server** : plage 192.168.100.3-50, passerelle pfSense
- Réservation DHCP pour SRV-AD1 : 192.168.100.3

```
Host Name . . . . . : SRV-AD2
Primary Dns Suffix . . . . . : monlab.local
Node Type . . . . . : Hybrid
IP Routing Enabled. . . . . : No
WINS Proxy Enabled. . . . . : No
DNS Suffix Search List. . . . . : monlab.local

Ethernet adapter Ethernet:

Connection-specific DNS Suffix . :
Description . . . . . : Intel(R) PRO/1000 MT Desktop Adapter
Physical Address. . . . . : 08-00-27-60-B0-F4
DHCP Enabled. . . . . : No
Autoconfiguration Enabled . . . . : Yes
Link-local IPv6 Address . . . . . : fe80::800e:3bd6:b760:4589%13(Preferred)
IPv4 Address. . . . . : 192.168.100.2(Preferred)
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 192.168.100.1
DHCPv6 IAID . . . . . : 101187623
DHCPv6 Client DUID. . . . . : 00-01-00-01-31-71-85-56-08-00-27-60-B0-F4
DNS Servers . . . . . : ::1
                        192.168.100.3
                        8.8.4.4
NetBIOS over Tcpip. . . . . : Enabled
```

4.2.3 Comptes utilisateurs créés

TABLE 4.1 – Comptes utilisateurs Active Directory

Utilisateur	OU	Accès
mohamed	MonLab-Users	AD + FTP + Windows + Linux
mariem	MonLab-Users	AD + FTP + Windows
youssef	MonLab-Users	AD + FTP
vpnuser	MonLab-Users	OpenVPN uniquement

4.3 Postes clients

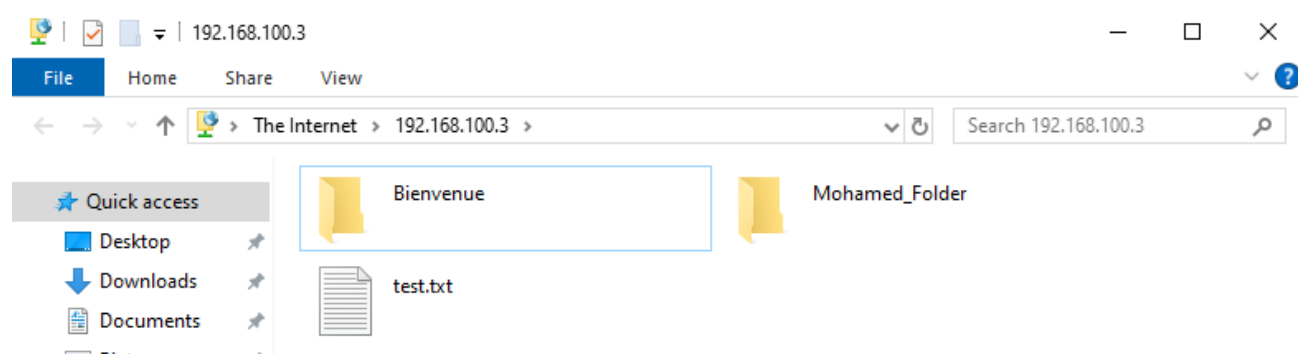
4.3.1 W-CLIENT (Windows 10)

- Joint au domaine `monlab.local`
- IP attribuée par DHCP depuis SRV-AD2
- Connexion testée avec les comptes `mohamed` et `mariem`
- Accès FTP validé via l'Explorateur Windows

```
Ethernet adapter Ethernet:

Connection-specific DNS Suffix  . : monlab.local
Link-local IPv6 Address . . . . . : fe80::ac8e:7537:d3d8:988e%6
IPv4 Address. . . . . : 192.168.100.5
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 192.168.100.1

C:\Users\mariem>
```



```

C:\Users\mariem>ftp 192.168.100.3
Connected to 192.168.100.3.
220 Microsoft FTP Service
200 OPTS UTF8 command successful - UTF8 encoding now ON.
User (192.168.100.3:(none)): mariem
331 Password required
Password:
230 User logged in.
ftp> dir
200 PORT command successful.
125 Data connection already open; Transfer starting.
04-15-26 08:28PM <DIR> Bienvenue
05-06-26 10:06PM <DIR> Mohamed_Folder
04-15-26 07:14PM 25 test.txt
226 Transfer complete.
ftp: 157 bytes received in 0.13Seconds 1.25Kbytes/sec.
ftp>

```

4.3.2 Debian (Debian 12 Bookworm)

La machine Debian a été jointe au domaine AD via la pile **realmd/sss/Kerberos** et connexion au serveur FTP :

>_ Jonction Debian 12 au domaine AD

```

1      # Installation des paquets necessaires
2
3      apt install realmd sssd adcli samba-common-
        bin krb5-user -y
4
5      # Decouverte du domaine
6      realm discover monlab.local */
7
8      # Jonction au domaine (avec compte
        administrateur AD)
9
10     realm join monlab.local -U Administrator

```

❗ Problème : Erreur Kerberos Preauthentication

Cause : Décalage d'horloge de 7 heures entre Debian et SRV-AD1 (Kerberos tolère 5 minutes max).

Solution : Synchronisation NTP : sur `ntpdate 192.168.100.3`

```
sami@sami:~$ ftp 192.168.100.3
Connected to 192.168.100.3.
220 Microsoft FTP Service
Name (192.168.100.3:sami): mohamed
331 Password required
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> dir
229 Entering Extended Passive Mode (|||49897|)
150 Opening ASCII mode data connection.
04-15-26 08:28PM <DIR> Bienvenue
05-06-26 10:06PM <DIR> Mohamed_Folder
04-15-26 07:14PM 25 test.txt
226 Transfer complete.
ftp> bye
221 Goodbye.
sami@sami:~$
```

4.4 VPN OpenVPN

4.4.1 Définition

OpenVPN est un logiciel open source qui permettant de créer des réseau privés virtuels sécurisés. Il est reconnu pour sa fiabilité, sa flexibilité et son haut niveau de sécurité, ce qui en fait une solution VPN de référence dans le monde professionnel.

4.4.2 Principes de fonctionnement

OpenVPN s'appuie sur des standards cryptographiques éprouvées pour garantir la sécurité des communications :

- Utilisation des protocoles **SSL/TLS** pour l'établissement du tunnel
- **Chiffrement** robuste des données (AES-256,...)
- **Authentification forte** via certificats numériques X.509
- Support des protocoles UDP et TCP

4.4.3 Configuration du serveur

TABLE 4.2 – Paramètres de configuration OpenVPN

Paramètre	Valeur
Type	Remote Access (SSL/TLS + User Authentication)
Interface	WAN
Protocole	UDP
Port	1194
Réseau tunnel	10.0.8.0/24
Réseau local	192.168.100.0/24
Chiffrement	AES-256-GCM
Digest	SHA256
Diffie-Hellman	2048 bits
Autorité de Certification	MonLab-CA

OpenVPN Servers					
Interface	Protocol / Port	Tunnel Network	Mode / Crypto	Description	Actions
WAN	UDP4 / 1194 (TUN)	10.0.8.0/24	Mode: Remote Access (SSL/TLS + User Auth) Data Ciphers: AES-256-GCM, AES-128-GCM, CHACHA20-POLY1305, AES-256-CBC Digest: SHA256 D-H Params: 2048 bits		  

4.4.4 Tests de connexion

La connexion d'une machine Windows à distance avec le réseau local.

```
C:\Users\user>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::ac8e:7537:d3d8:988e%7
    IPv4 Address. . . . . : 10.0.2.7
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 10.0.2.1

Unknown adapter OpenVPN TAP-Windows6:

    Connection-specific DNS Suffix  . : monlab.local
    Link-local IPv6 Address . . . . . : fe80::6fa9:15a:c23:fb7d%15
    IPv4 Address. . . . . : 10.0.8.2
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 

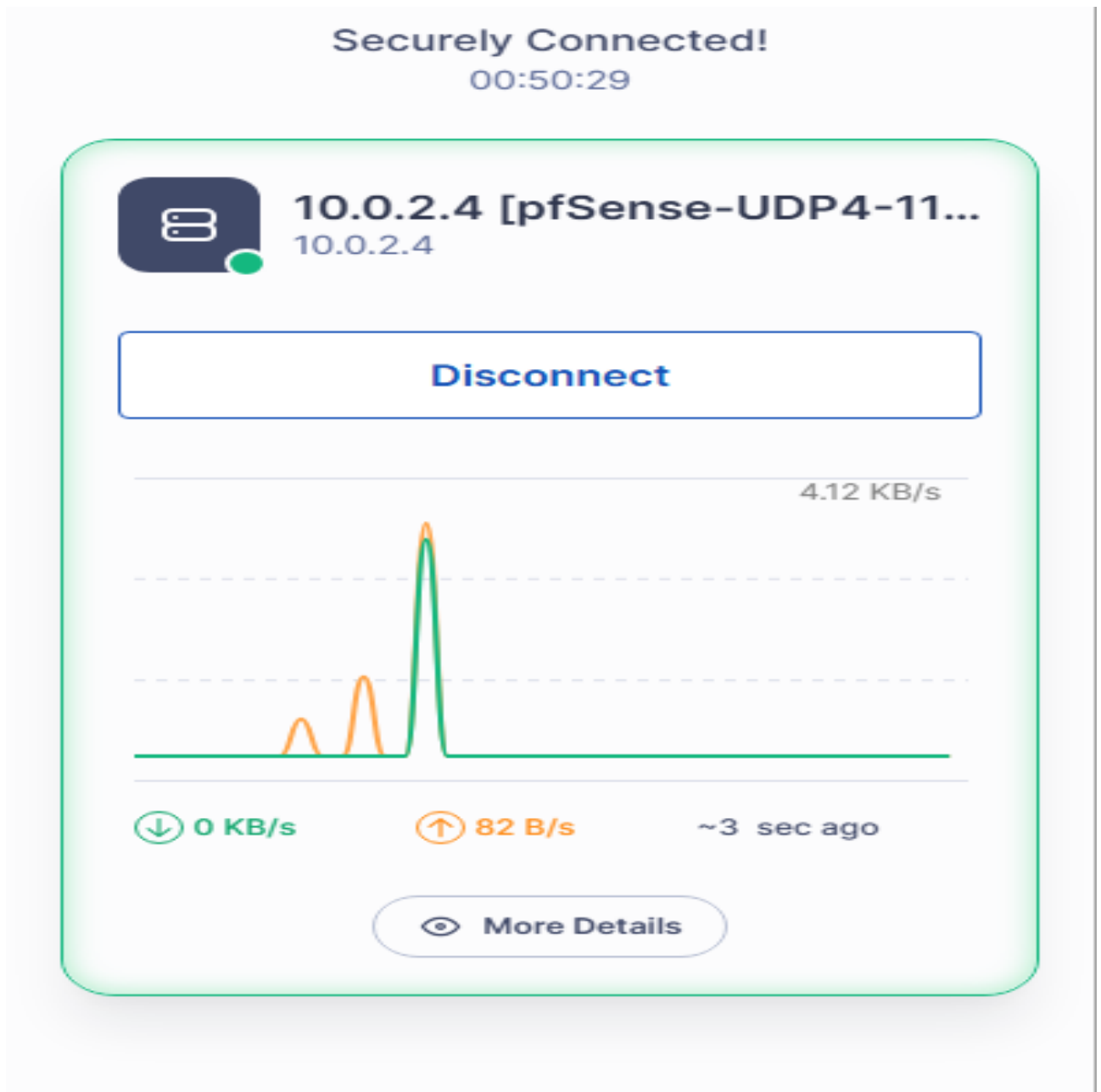
Unknown adapter OpenVPN Data Channel Offload:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . : 

C:\Users\user>ping 192.168.100.3

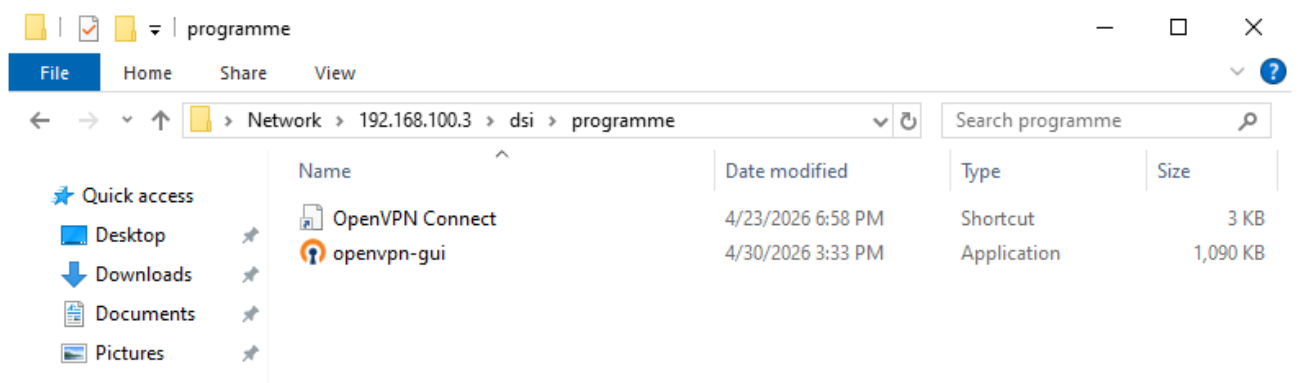
Pinging 192.168.100.3 with 32 bytes of data:
Reply from 192.168.100.3: bytes=32 time=21ms TTL=127
Reply from 192.168.100.3: bytes=32 time=10ms TTL=127
Reply from 192.168.100.3: bytes=32 time=7ms TTL=127
Reply from 192.168.100.3: bytes=32 time=6ms TTL=127

Ping statistics for 192.168.100.3:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 6ms, Maximum = 21ms, Average = 11ms
```



4.4.5 L'accès au partage par openVPN

Sur la même machine windows on peut accéder au partage via le tunnel VPN.



Chapitre 5

Déploiement et Configuration de Suricata IDS/IPS

5.1 Installation de Suricata sur pfSense

Suricata est disponible nativement dans le gestionnaire de packages de pfSense. L'installation s'effectue via l'interface web d'administration :

1. Accéder à **System > Package Manager > Available Packages**
2. Rechercher **suricata** et cliquer sur **Install**
3. Attendre la fin de l'installation automatique

5.2 Configuration générale

5.2.1 Paramètres principaux

 **Configuration Suricata**

Interface surveillée :	LAN (em1)
Mode de fonctionnement :	IPS — Block Offenders (Legacy Mode)
Hardware Offloading :	Désactivé (3 options)

 **Important : Hardware Offloading**

Le Hardware Offloading doit être **désactivé** (LRO, TSO, GSO) pour garantir le bon fonctionnement de Suricata. Sans cela, des paquets peuvent être mal reconstitués et échapper à l'analyse.

- LRO (Large Receive Offload) — regroupe plusieurs paquets entrants en un seul gros paquet avant de l'envoyer au CPU.
- TSO (TCP Segmentation Offload) — découpe les gros segments TCP directement sur la carte réseau.
- GSO (Generic Segmentation Offload) — version logicielle/générique de TS.

5.3 Règles Emerging Threats

5.3.1 Téléchargement des règles

```

1      # Dans pfSense : Services > Suricata > Updates
2      # Sélectionner "Emerging Threats Open" (ETOpen)
3      # Cliquer "Update Rules"
4      # Resultat : +30 000 signatures telechargees

```

Listing 5.1 – Mise à jour des règles Emerging Threats

Services / Suricata / Updates

[Interfaces](#)
[Global Settings](#)
[Updates](#)
[Alerts](#)
[Blocks](#)
[Files](#)
[Pass Lists](#)
[Suppress](#)
[Logs View](#)
[Logs Mgmt](#)
[SID Mgmt](#)
[Sync](#)

[IP Lists](#)

INSTALLED RULE SET MD5 SIGNATURES

Rule Set Name/Publisher	MD5 Signature Hash	MD5 Signature Date
Emerging Threats Open Rules	d0acdc86e5aa9f21ed36745e62e621	Friday, 08-May-26 10:35:09 UTC
Snort Subscriber Rules	Not Enabled	Not Enabled
Snort GPLv2 Community Rules	Not Enabled	Not Enabled
Feodo Tracker Botnet C2 IP Rules	Not Enabled	Not Enabled
ABUSE.ch SSL Blacklist Rules	Not Enabled	Not Enabled

UPDATE YOUR RULE SET

Last Update: May-08 2026 19:22
Result: success

✓ Update

↓ Force

5.3.2 Catégories de règles activées

TABLE 5.1 – Catégories de règles Suricata activées

Catégorie	Description	Exemples de détection
emerging-scan	Détection de scans réseau	Nmap SYN scan, XMAS scan
emerging-exploit	Exploits connus	EternalBlue, Heartbleed
emerging-malware	Logiciels malveillants	Trojans, ransomware
emerging-dos	Déni de service	SYN flood, ping flood
emerging-ftp	Attaques FTP	Brute force, accès anonyme
emerging-web_server	Attaques web	XSS, injection SQL
emerging-policy	Violations de politique	Protocoles non autorisés
emerging-trojan	Chevaux de Troie	Communications C&C

5.4 Modes de fonctionnement

5.4.1 Mode IDS (Détection seule)

En mode IDS, Suricata analyse le trafic en miroir (*tap mode*) et génère uniquement des alertes sans intervenir sur le flux réseau. Ce mode est recommandé en phase initiale pour calibrer les règles et éliminer les faux positifs.

5.4.2 Mode IPS (Prévention active)

En mode IPS (*Block Offenders*, Legacy Mode), Suricata est positionné *en ligne* entre le réseau et Internet. Tout paquet correspondant à une règle avec l’action **drop** ou **reject** est bloqué automatiquement.

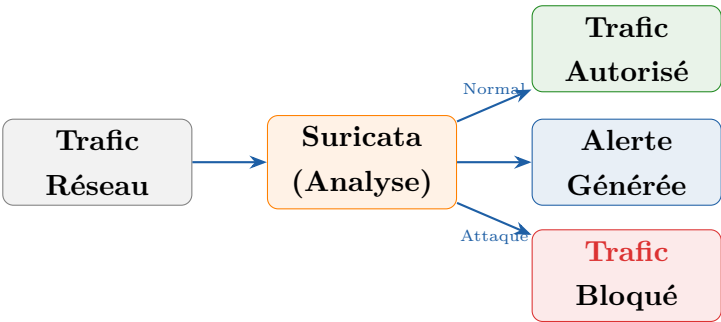


FIGURE 5.1 – Flux de traitement du trafic par Suricata en mode IPS

5.5 Statut Suricata

— Interface LAN surveillée, règles ET chargées, mode IPS actif.

Services / Suricata

Interfaces Global Settings Updates Alerts Blocks Files Pass Lists Suppress Logs View Logs Mgmt SID Mgmt Sync

IP Lists

Interface Settings Overview					
Interface	Suricata Status	Pattern Match	Blocking Mode	Description	Actions
☒ LAN (em1)	  	AUTO	INLINE IPS	LAN	 
☐ WAN (em0)	  	AUTO	LEGACY MODE	WAN	 





Chapitre 6

Tests d’Intrusion et Analyse des Résultats

6.1 Environnement de test

Cadre éthique et légal

Important : Toutes les attaques ont été réalisées dans un environnement virtualisé **entièrement isolé** sous Oracle VirtualBox. Aucun réseau réel n’a été ciblé. Cette approche garantit la sécurité et la conformité légale du projet.

6.2 Outils d’attaque utilisés

TABLE 6.1 – Outils de tests d’intrusion

Outil	Description	Version / Plateforme
Nmap	Scanner de ports et de vulnérabilités	7.93 / Kali Linux
Hydra	Outil de brute force (FTP, SSH, HTTP)	9.5 / Kali Linux
curl	Client HTTP en ligne de commande	Kali Linux / Debian
Wireshark	Analyseur de paquets réseau	Kali Linux

6.3 Scénarios d'attaque et résultats

6.3.1 Test sur LAN :

Test 1 : Validation IDS (testmynids.org)

Après le blocage de l'alerte GPL ATTACK_RESPONSE , l'attaque curl ne retourne rien et IDS l'affiche en rouge ce qui signifie le blocage de l'IPS.

```
1
2 curl http://testmynids.org/uid/index.html
```

Listing 6.1 – Test de détection IDS basique

Alerte Suricata générée

Règle : GPL ATTACK_RESPONSE id check returned root

GID :SID : 1:2100498 **Priorité :** 2

Explication : La réponse HTTP contient la chaîne caractéristique d'un retour de commande id exécutée en root, signature d'une compromission système.

```
root@sami:~# curl testmynids.org/uid/index.html
uid=0(root) gid=0(root) groups=0(root)
root@sami:~# curl testmynids.org/uid/index.html
uid=0(root) gid=0(root) groups=0(root)
root@sami:~# curl testmynids.org/uid/index.html
^C
root@sami:~#
```

Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
05/09/2026 23:03:08		2	TCP	Potentially Bad Traffic	52.85.47.4 	80	192.168.100.4 	40934	1:2100498   	GPL ATTACK_RESPONSE id check returned root
05/09/2026 23:01:11		2	TCP	Potentially Bad Traffic	18.239.36.114 	80	192.168.100.4 	42580	1:2100498   	GPL ATTACK_RESPONSE id check returned root
05/09/2026 23:00:02		2	TCP	Potentially Bad Traffic	52.222.132.64 	80	192.168.100.4 	38314	1:2100498   	GPL ATTACK_RESPONSE id check returned root

Test 2 : Scan SYN (Half-Open)

```
1 nmap -sS 192.168.100.1
```

Listing 6.2 – Scan SYN Nmap



Alerte Suricata générée

Règle : ET SCAN Possible Nmap User-Agent Observed

GID :SID : 1:2024364 **Priorité :** 1 (CRITIQUE)

Explication : L'en-tête HTTP User-Agent contient la signature de Nmap, révélant une reconnaissance active.

```
root@sami:~# nmap -sS 192.168.100.1
Starting Nmap 7.93 ( https://nmap.org ) at 2026-05-11 06:07 EDT
Nmap scan report for 192.168.100.1
Host is up (0.0030s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
MAC Address: 08:00:27:3A:A4:0B (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 5.10 seconds
root@sami:~#
```

Last 250 Alert Entries. (Most recent entries are listed first)

Note: Alerts triggered by DROP rules that resulted in dropped (blocked) packets are shown with highlighted rows below.

Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
05/11/2026 10:06:27		1	TCP	Web Application Attack	192.168.100.4 	59228	192.168.100.1 	80	1:2024364 	ET SCAN Possible Nmap User-Agent Observed
05/11/2026 10:06:27		3	TCP	Generic Protocol Command Decode	192.168.100.1 	80	192.168.100.4 	59226	1:2260000 	SURICATA Applayer Mismatch protocol both directions
05/11/2026 10:06:27		1	TCP	Web Application Attack	192.168.100.4 	59216	192.168.100.1 	80	1:2024364 	ET SCAN Possible Nmap User-Agent Observed
05/11/2026 10:06:26		3	TCP	Generic Protocol Command Decode	192.168.100.1 	80	192.168.100.4 	59202	1:2260000 	SURICATA Applayer Mismatch protocol both directions
05/11/2026 10:06:26		1	TCP	Web Application Attack	192.168.100.4 	59198	192.168.100.1 	80	1:2024364 	ET SCAN Possible Nmap User-Agent Observed

Test 3 : Scan Agressif (-A -T4)

1

```
nmap -A -T4 192.168.100.1
```

Listing 6.3 – Scan agressif Nmap

```
root@sami:~# nmap -A -T4 192.168.100.1
Starting Nmap 7.93 ( https://nmap.org ) at 2026-05-09 19:20 EDT
Nmap scan report for pfSense.monlab.lan (192.168.100.1)
Host is up (0.0031s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.7 (protocol 2.0)
53/tcp    open  domain   Unbound
80/tcp    open  http     nginx
|_http-title: Did not follow redirect to https://pfSense.monlab.lan/
443/tcp   open  ssl/http nginx
| ssl-cert: Subject: commonName=pfSense-69df4fdde1776/organizationName=pfSense G
UI default Self-Signed Certificate
| Subject Alternative Name: DNS:pfSense-69df4fdde1776
| Not valid before: 2026-04-15T08:44:14
|_Not valid after: 2027-05-18T08:44:14
|_http-title: pfSense - Login
MAC Address: 08:00:27:3A:A4:0B (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 o
pen and 1 closed port
Device type: general purpose
Running (JUST GUESSING): FreeBSD 11.X (92%)
OS CPE: cpe:/o:freebsd:freebsd:11.2
```

05/09/2026 23:21:32		1	TCP	Web Application Attack	192.168.100.4  	60948	192.168.100.1  	80	1:2024364   	ET SCAN Possible Nmap User-Agent Observed
05/09/2026 23:19:31		1	TCP	Web Application Attack	192.168.100.4  	32888	192.168.100.1  	80	1:2024364   	ET SCAN Possible Nmap User-Agent Observed
05/09/2026 23:19:31		1	TCP	Web Application Attack	192.168.100.4  	32876	192.168.100.1  	80	1:2024364   	ET SCAN Possible Nmap User-Agent Observed
05/09/2026 23:19:31		1	TCP	Web Application Attack	192.168.100.4  	32860	192.168.100.1  	80	1:2024364   	ET SCAN Possible Nmap User-Agent Observed
05/09/2026 23:19:31		1	TCP	Web Application Attack	192.168.100.4  	32848	192.168.100.1  	80	1:2024364   	ET SCAN Possible Nmap User-Agent Observed
05/09/2026 23:19:31		1	TCP	Web Application Attack	192.168.100.4  	32846	192.168.100.1  	80	1:2024364   	ET SCAN Possible Nmap User-Agent Observed
05/09/2026 23:19:31		1	TCP	Web Application Attack	192.168.100.4  	32840	192.168.100.1  	80	1:2024364   	ET SCAN Possible Nmap User-Agent Observed
05/09/2026 23:19:30		1	TCP	Web Application Attack	192.168.100.4  	32838	192.168.100.1  	80	1:2024364   	ET SCAN Possible Nmap User-Agent Observed
05/09/2026 23:19:30		1	TCP	Web Application Attack	192.168.100.4  	32824	192.168.100.1  	80	1:2024364   	ET SCAN Possible Nmap User-Agent Observed

Résultat : **multiples alertes** de catégories ET SCAN et ET WEB générées simultanément, priorité 1.

Après le blocage des alertes :

```
root@sami:~# nmap -A -T4 192.168.100.1
Starting Nmap 7.93 ( https://nmap.org ) at 2026-05-09 19:26 EDT

root@sami:~#
```

Last 250 Alert Entries. (Most recent entries are listed first)										
Note: Alerts triggered by DROP rules that resulted in dropped (blocked) packets are shown with highlighted rows below.										
Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
05/09/2026 23:30:34		1	TCP	Web Application Attack	192.168.100.4	48466	192.168.100.1	80	1:2024364	ET SCAN Possible Nmap User-Agent Observed
05/09/2026 23:30:34		1	TCP	Web Application Attack	192.168.100.4	48460	192.168.100.1	80	1:2024364	ET SCAN Possible Nmap User-Agent Observed
05/09/2026 23:30:34		1	TCP	Web Application Attack	192.168.100.4	48446	192.168.100.1	80	1:2024364	ET SCAN Possible Nmap User-Agent Observed
05/09/2026 23:30:34		1	TCP	Web Application Attack	192.168.100.4	48432	192.168.100.1	80	1:2024364	ET SCAN Possible Nmap User-Agent Observed
05/09/2026 23:30:34		1	TCP	Web Application Attack	192.168.100.4	48418	192.168.100.1	80	1:2024364	ET SCAN Possible Nmap User-Agent Observed
05/09/2026 23:30:34		3	TCP	Generic Protocol Command Decode	192.168.100.1	80	192.168.100.4	48416	1:2260000	SURICATA Applayer Mismatch protocol both directions
05/09/2026 23:30:34		3	TCP	Generic Protocol Command	192.168.100.1	80	192.168.100.4	48412	1:2260000	SURICATA Applayer Mismatch protocol both directions

Test 4 : Scan de vulnérabilités (NSE)

```
1 nmap --script vuln 192.168.100.1
```

Listing 6.4 – Scan de vulnérabilités Nmap

Résultat : Alertes ET WEB et ET EXPLOIT générées, priorités 1 et 2.

Tests 5, 6, 7 : Scans spéciaux (XMAS, FIN, NULL)

```
1 nmap -sX 192.168.100.1 # Scan XMAS (FIN+PSH+URG)
2 nmap -sF 192.168.100.1 # Scan FIN
3 nmap -sN 192.168.100.1 # Scan NULL (aucun flag TCP)
```

Listing 6.5 – Scans atypiques

Ces scans tentent de contourner les pare-feux basiques en envoyant des paquets avec des combinaisons de flags TCP inhabituelles. Suricata les a tous détectés (priorité 2).

Test 8 : Brute Force FTP (Hydra)

```
1 hydra -l mohamed -P /usr/share/wordlists/rockyou.txt \
2 ftp://192.168.100.3
```

Listing 6.6 – Attaque brute force FTP

Alerte Suricata générée

Règle : Catégorie **emerging-ftp**

Priorité : 1 (CRITIQUE)

Explication : Les tentatives de connexion répétées et rapides sur le port 21 constituent une signature de force brute, détectée par le pattern de la règle FTP.

6.3.2 Test sur WAN :

Test : Scan SYN (Half-Open)

```
1 nmap -sS 192.168.100.3
```

Listing 6.7 – Scan SYN Nmap

Alerte Suricata générée

Règle : **ET SCAN Possible Nmap User-Agent Observed**

GID :SID : 1:2024364 Priorité : 1 (CRITIQUE)

Explication : L'en-tête HTTP User-Agent contient la signature de Nmap, révélant une reconnaissance active. Résultat : **multiples alertes** de catégories ET SCAN et ET WEB générées simultanément, priorité 1.

Cette attaque a été menée sur une machine Kali Linux hors du réseau local ayant l'IP 10.0.2.5 .

```
(sami@sami)-[~]
$ nmap -sS 192.168.100.3
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-10 15:49
-0400
Nmap scan report for 192.168.100.3
Host is up (0.051s latency).
Not shown: 985 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
53/tcp    open  domain
80/tcp    open  http
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
443/tcp   open  https
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5985/tcp  open  wsman
Nmap done: 1 IP address (1 host up) scanned in 8.30 seconds
(sami@sami)-[~]
$
```

Last 250 Alert Entries. (Most recent entries are listed first)										
Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
07/05/2026 17:16:48		2	TCP	Potentially Bad Traffic	10.0.2.15 X	57442	192.168.100.3 	1521	1:2010936 X	ET SCAN Suspicious inbound to Oracle SQL port 1521
07/05/2026 17:16:48		2	TCP	Potentially Bad Traffic	10.0.2.15 X	57440	192.168.100.3 	1521	1:2010936 X	ET SCAN Suspicious inbound to Oracle SQL port 1521
07/05/2026 17:16:47		2	TCP	Potentially Bad Traffic	10.0.2.15 X	57442	192.168.100.3 	5432	1:2010939 X	ET SCAN Suspicious inbound to PostgreSQL port 5432
07/05/2026 17:16:47		2	TCP	Potentially Bad Traffic	10.0.2.15 X	57442	192.168.100.3 	1433	1:2010935 X	ET SCAN Suspicious inbound to MSSQL port 1433
07/05/2026 17:16:47		2	TCP	Potentially Bad Traffic	10.0.2.15 X	57440	192.168.100.3 	5432	1:2010939 X	ET SCAN Suspicious inbound to PostgreSQL port 5432
07/05/2026 17:16:47		2	TCP	Attempted Information Leak	10.0.2.15 X	57440	192.168.100.3 	5815	1:2002910 X	ET SCAN Potential VNC Scan 5800-5820
07/05/2026 17:16:47		2	TCP	Potentially Bad Traffic	10.0.2.15 X	57440	192.168.100.3 	1433	1:2010935 X	ET SCAN Suspicious inbound to MSSQL port 1433
07/05/2026 17:16:45		2	TCP	Potentially Bad Traffic	10.0.2.15 X	57442	192.168.100.3 	3306	1:2010937 X	ET SCAN Suspicious inbound to MySQL port

Après le blocage des alertes :

IP Lists

Blocked Hosts Log View Settings

Save or Remove Hosts
Download
All blocked hosts will be saved

Clear
All blocked hosts will be cleared

Save Settings
Save
Save auto-refresh and view settings

☒ Refresh
Default is ON

500
Number of blocked entries to view. Default is 500

Last 500 Hosts Blocked by Suricata

Note: Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab.

Blocked IP	Block Date/Time	Block Alert Description	Block Rule GID:SID	Remove Block
10.0.2.15	07/05/2026 17:16:44	GPL SCAN PING NMAP	1:2100469	
	07/05/2026 01:02:15	ET SCAN MS Terminal Server Traffic on Non-standard Port	1:2023753	
	07/05/2026 00:59:43	GPL SCAN PING NMAP	1:2100469	
	07/04/2026 17:04:11	GPL SCAN PING NMAP	1:2100469	
	06/11/2026 12:35:38	GPL SCAN PING NMAP	1:2100469	
	06/11/2026 09:56:07	ET SCAN NMAP -sA (1)	1:2000538	
	06/11/2026 09:38:00	ET SCAN NMAP -sA (1)	1:2000538	
	05/31/2026 00:57:35	ET SCAN Suspicious inbound to MySQL port 3306	1:2010937	
	05/31/2026 00:35:54	ET SCAN Suspicious inbound to MySQL port 3306	1:2010937	

1 host IP address is currently being blocked.

6.4 Tableau récapitulatif des tests

TABLE 6.2 – Résultats complets des tests d'intrusion

Type attaque	d'at-	Alerte Suricata	GID :SID	Priorité
Test IDS clas- sique		GPL AT- TACK_RESPONSE id check returned root	1 :2100498	2
Scan SYN		ET SCAN Possible Nmap User-Agent	1 :2024364	1
Scan Agressif (- A)		Multiples ET SCAN + ET WEB	Multiples	1
Scan vulnérabili- tés		ET WEB + ET EX- PLOIT	Multiples	1-2
Scan XMAS		Flags TCP anormaux	Multiples	2
Scan FIN		Paquets FIN isolés	Multiples	2
Scan NULL		Paquets sans flags TCP	Multiples	2
Brute Force FTP		Tentatives multiples FTP	Multiples	1

6.5 Système de priorités des alertes

TABLE 6.3 – Niveaux de priorité des alertes Suricata

Priorité	Niveau	Signification	Action recommandée
1	CRITIQUE	Attaque active détec- tée	Action immédiate, blocage automatique (IPS)
2	HAUTE	Trafic suspect	Investigation requise, sur- veillance renforcée
3	MOYENNE	Activité inhabituelle	À surveiller, possible faux positif
4		Information	Journalisation uniquement

6.6 Analyse et interprétation

6.6.1 Efficacité du système

Les tests d'intrusion ont démontré l'efficacité de Suricata. En mode IDS, il assure une détection fiable des activités malveillantes grâce à la génération d'alertes en temps réel. En mode IPS, il détecte les attaques puis bloque automatiquement les paquets malveillants, garantissant ainsi une protection active contre l'ensemble des vecteurs d'attaque testés :

- ✔ **Scans de ports** : détecté (SYN, XMAS, FIN, NULL)
- ✔ **Brute force FTP** : détecté en priorité 1
- ✔ **Exploitation** : alertes ET EXPLOIT générées
- ❗ **Faux positifs** : apt update, Windows Update → priorité 3 (normal)

6.6.2 Gestion des faux positifs

La distinction entre vrais positifs (attaques réelles) et faux positifs (trafic légitime) est une compétence essentielle pour l'administrateur sécurité. Les alertes de priorité 3 générées par cmdapt update ou Windows Update sont attendues et ne nécessitent aucune action.

Chapitre 7

Immersion en Production : Compléments de sécurité XDR (ESET)

Au-delà de la conception du laboratoire virtualisé, le stage à la Banque Nationale de Mauritanie a offert l'opportunité d'une immersion directe dans l'environnement de production de la Direction des Systèmes d'Information. Cette expérience a permis de découvrir les solutions de sécurité réellement déployées au sein d'un établissement bancaire et de contribuer activement à leur exploitation. Le présent chapitre est consacré à la solution **XDR ESET**, l'une des pierres angulaires de la stratégie de sécurité des endpoints à la BNM.

7.1 Présentation générale de la solution ESET XDR

XDR (*Extended Detection and Response*) désigne une nouvelle génération de solutions de cybersécurité qui étendent la portée des outils EDR (*Endpoint Detection and Response*) traditionnels. Là où un antivirus classique se contente d'analyser les fichiers à partir d'une base de signatures connues, une solution XDR adopte une approche **comportementale et corrélée**, capable de détecter des menaces avancées en analysant le comportement des processus, du trafic réseau et des activités utilisateurs sur l'ensemble du parc informatique.

ESET est un éditeur slovaque de solutions de cybersécurité, reconnu mondialement pour la qualité et la légèreté de ses produits. Sa plateforme XDR, déployée à la BNM, offre une visibilité centralisée sur l'ensemble des postes et serveurs de la banque via la console **ESET PROTECT**, et combine plusieurs couches de protection : antivirus, anti-ransomware, contrôle des périphériques, pare-feu local et détection comportementale avancée grâce au module **ESET Inspect**.

Pourquoi le XDR dans le secteur bancaire ?

Dans un environnement bancaire, les menaces ne se limitent plus aux malwares classiques. Les attaques modernes utilisent souvent des techniques de *living-off-the-land* (exploitation d'outils légitimes du système), des mouvements latéraux discrets ou des malwares sans fichier. Une solution XDR est essentielle pour détecter ces comportements anormaux et réagir rapidement avant qu'une compromission ne se propage.

7.2 Mécanismes de détection et de protection

L'étude approfondie de la console ESET PROTECT, réalisée lors d'échanges avec l'équipe ESET, a permis d'appréhender les principaux mécanismes mis en œuvre par la solution.

7.2.1 Détection des intrusions et des menaces

ESET XDR repose sur une approche multicouche combinant plusieurs technologies de détection. La **détection par signatures** identifie les malwares et virus connus à partir d'une base de données régulièrement mise à jour par le cloud ESET LiveGrid. L'**analyse heuristique** examine le code et le comportement des fichiers exécutables pour détecter les variantes inconnues de menaces. Enfin, l'**analyse comportementale**, assurée par le moteur *ESET Inspect*, surveille en temps réel les actions des processus sur le poste (modifications du registre, accès aux fichiers sensibles, communications réseau suspectes) pour identifier des intrusions actives, y compris celles qui exploitent des vulnérabilités *zero-day*.

7.2.2 Blocage automatique des menaces

Lorsqu'une menace est identifiée, ESET XDR applique automatiquement une politique de blocage adaptée à son niveau de criticité. Les fichiers malveillants sont **mis en quarantaine** dans un espace isolé du système, empêchant toute exécution ultérieure. Les processus suspects sont **terminés immédiatement** et les connexions réseau associées sont **coupées**. Cette réaction automatisée intervient en quelques secondes, sans nécessiter d'intervention humaine, ce qui est crucial pour limiter l'impact d'une attaque rapide telle qu'un ransomware.

7.2.3 Système d'alertes en temps réel

Chaque détection génère une **alerte** envoyée à la console centrale d'administration, où elle est classifiée selon son niveau de gravité (informatif, avertissement, critique). Les administrateurs reçoivent des notifications immédiates pour les incidents prioritaires, accompagnées de l'ensemble des informations contextuelles : nom du poste concerné, utilisateur connecté, type de menace, chemin du fichier incriminé, horodatage et action appliquée. Cette traçabilité fine permet à l'équipe sécurité de la BNM de mener des investigations approfondies et de constituer un historique exploitable à des fins forensiques.

7.2.4 Isolation des machines compromises

L'une des fonctionnalités les plus puissantes d'ESET XDR est la capacité à **isoler à distance** un poste suspect du reste du réseau. En cas de détection d'une compromission avérée, l'administrateur peut, en un seul clic depuis la console, couper toutes les communications réseau de la machine infectée, à l'exception du canal sécurisé reliant l'agent ESET à la console. Cette isolation **empêche la propagation latérale** de la menace vers d'autres postes ou serveurs critiques, tout en permettant aux analystes de poursuivre l'investigation à distance et de mener les actions de remédiation nécessaires.

7.3 Déploiement de l'agent ESET sur le parc bancaire

Dans le cadre de cette immersion, une mission concrète et significative a été confiée : le **déploiement de l'agent XDR ESET sur plus de quatre-vingts postes** de la banque. Cette intervention sur le terrain a permis de mettre en pratique les connaissances théoriques acquises et de se confronter à la réalité de l'exploitation d'un parc informatique bancaire.

7.3.1 Préparation et installation du package

Pour chaque poste, le déploiement débute par le lancement du **Package Installer** préparé depuis la console centrale ESET. Cet installateur regroupe les trois composants essentiels : l'*ESET Management Agent*, qui assure la communication avec le serveur central, l'*ESET Endpoint Security*, qui constitue le moteur de protection principal, et l'*ESET Inspect Connector*, qui transmet les données comportementales nécessaires aux fonctionnalités XDR.

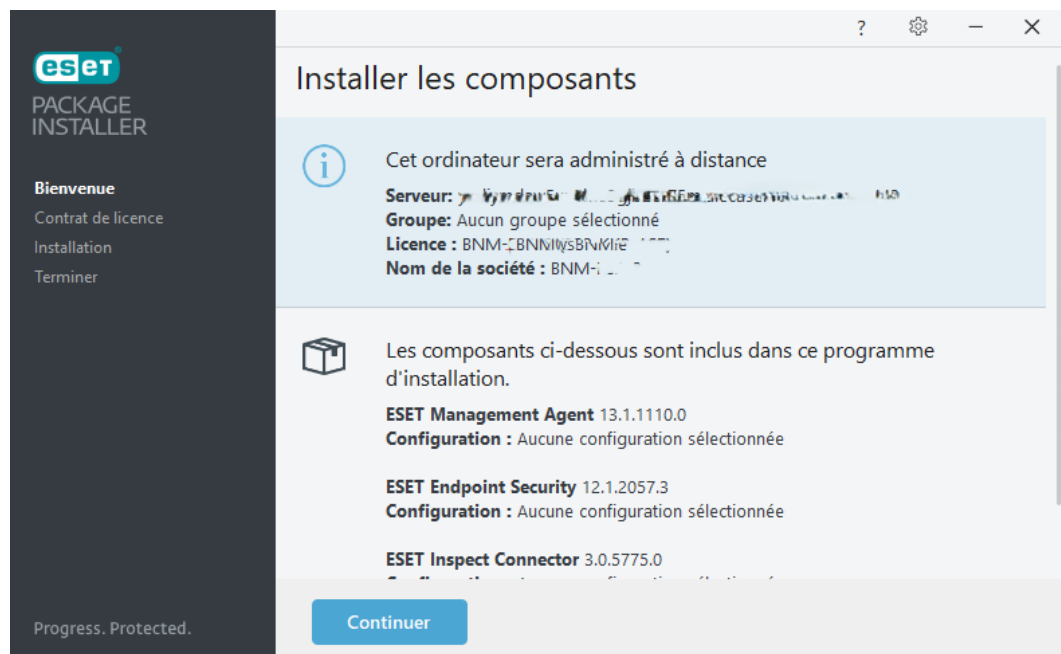


FIGURE 7.1 – Package Installer ESET : sélection des composants et rattachement à la licence BNM

Le poste est automatiquement rattaché au serveur de gestion de la banque ainsi qu'à la licence d'entreprise (BNM-EBA-3). Une fois la procédure validée, l'installation se déroule de manière entièrement automatisée jusqu'à la confirmation de réussite.

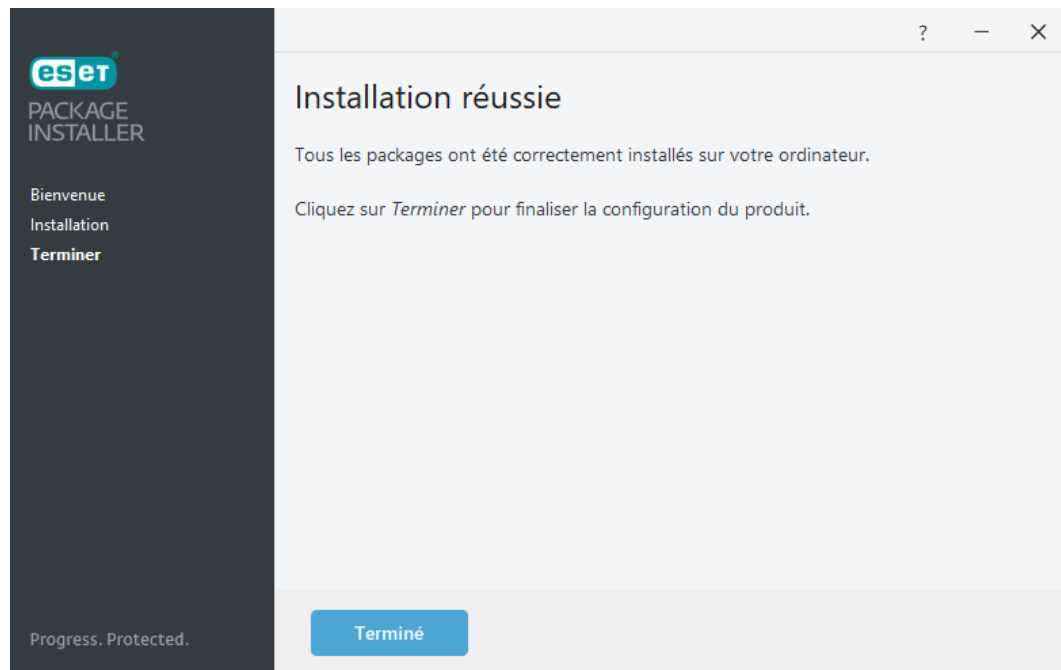


FIGURE 7.2 – Confirmation de l’installation réussie des trois composants ESET

Un redémarrage du poste est ensuite proposé afin de finaliser l’activation de l’ensemble des modules de protection.

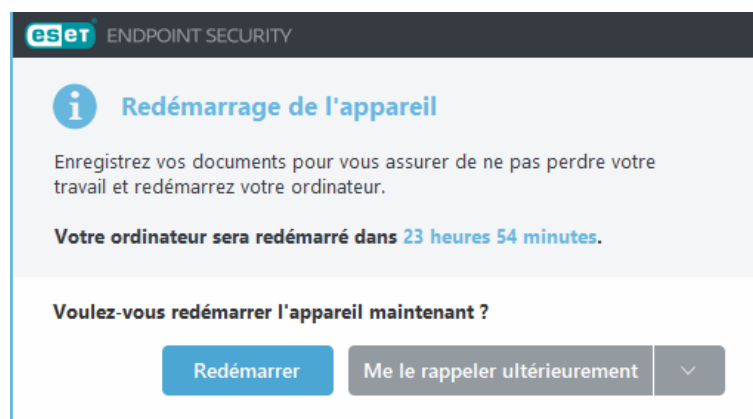


FIGURE 7.3 – Invite de redémarrage du poste après installation des composants

7.3.2 Initialisation et activation de la protection

Au premier démarrage suivant l’installation, ESET Endpoint Security entre dans une phase d’**initialisation de la protection**, durant laquelle les modules sont mis à jour et la configuration appliquée. Cette étape est essentielle pour synchroniser l’agent avec les politiques de sécurité définies par l’équipe de la BNM.

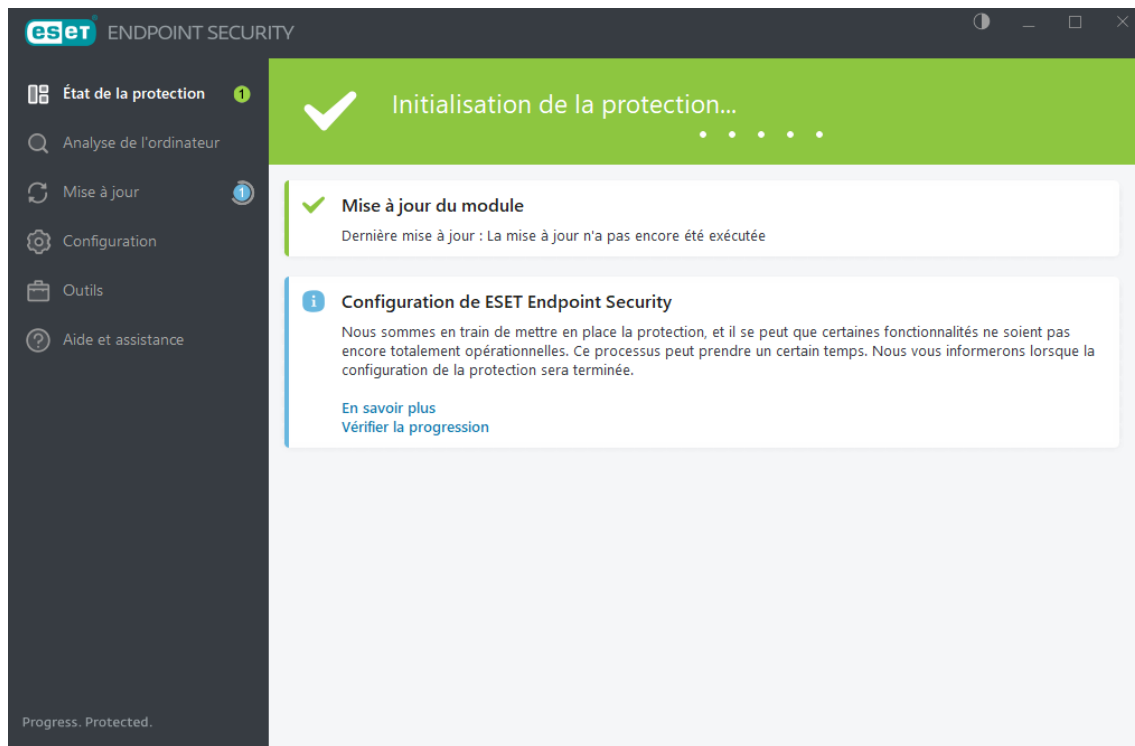


FIGURE 7.4 – Phase d’initialisation de la protection après installation

Une fois cette initialisation terminée, l’interface affiche le statut « **Vous êtes protégé** » accompagné de la date de dernière mise à jour des modules, indiquant que le poste est désormais pleinement opérationnel et supervisé depuis la console centrale.

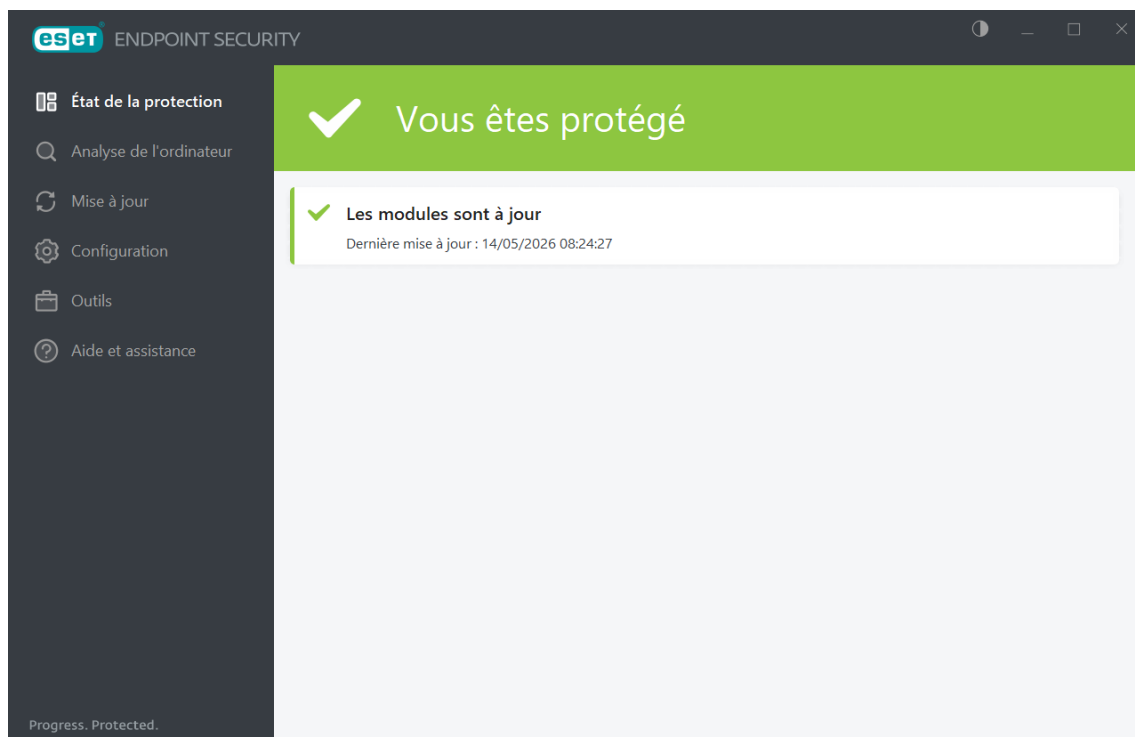


FIGURE 7.5 – Poste protégé et modules à jour après initialisation

7.3.3 Analyse initiale et vérification du poste

Pour valider l'intégrité du poste fraîchement protégé, une **analyse complète de l'ordinateur** est lancée systématiquement après l'installation. Cette analyse parcourt l'ensemble des fichiers du système afin de détecter d'éventuelles menaces préexistantes que le poste aurait pu accumuler avant la mise en place de la protection.

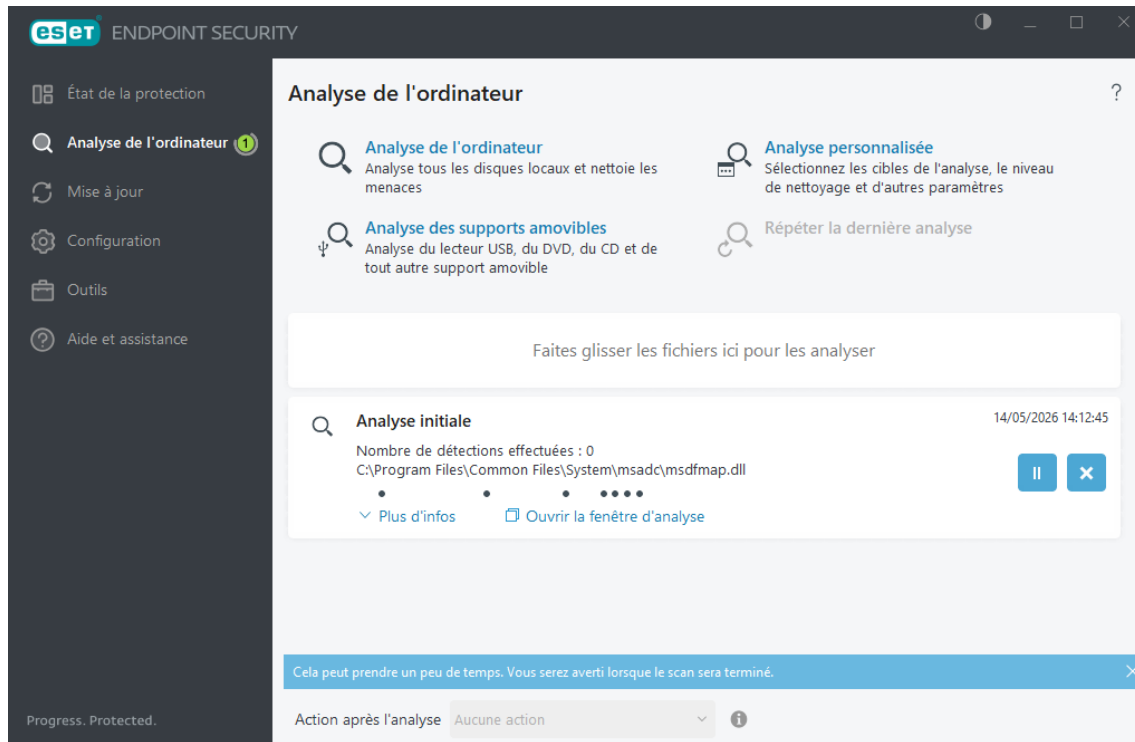


FIGURE 7.6 – Lancement de l'analyse initiale du poste

7.3.4 Gestion des règles du pare-feu local

ESET Endpoint Security embarque un **pare-feu local** dont les règles définissent comment les connexions réseau entrantes et sortantes sont traitées. Ces règles sont évaluées de haut en bas, et la première règle correspondante détermine l'action appliquée (autoriser ou bloquer). Cette granularité fine permet de restreindre précisément les applications autorisées à communiquer sur le réseau bancaire.

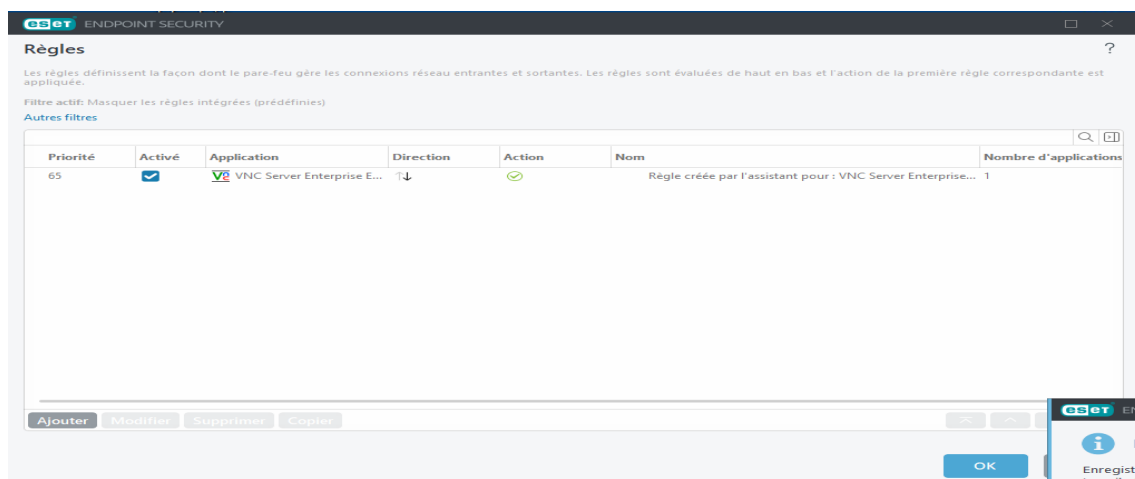


FIGURE 7.7 – Console de gestion des règles du pare-feu local ESET

7.3.5 Dépannage de l'accès réseau

L'interface de **dépannage de l'accès réseau** d'ESET s'est révélée particulièrement utile lors des interventions sur le parc. Cet outil affiche en temps réel les applications dont les connexions ont été bloquées par le pare-feu local, avec leur niveau de réputation et le nombre de blocages effectués. Il permet, après vérification, de débloquent rapidement une application légitime (par exemple un client d'administration distante) qui aurait été restreinte à tort.

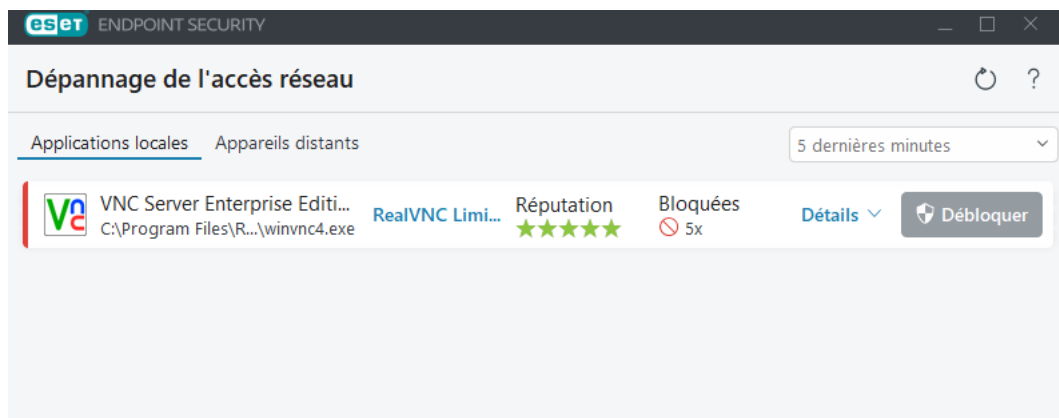


FIGURE 7.8 – Interface de dépannage de l'accès réseau et déblocage d'applications

7.3.6 Résolution de problèmes annexes

Au cours de ces interventions, plusieurs problèmes techniques annexes ont été identifiés et résolus sur certains postes, en particulier des dysfonctionnements liés à la **résolution DNS** et à la **connectivité réseau** qui empêchaient l'agent ESET de communiquer correctement avec la console centrale. Ces difficultés ont nécessité un travail de diagnostic méthodique (vérification de la configuration IP, tests de résolution de noms, contrôle des règles pare-feu locales) et ont contribué à renforcer les compétences pratiques en administration réseau et en support utilisateur en environnement professionnel.

7.4 Console ESET PROTECT : supervision centralisée du parc

La console web **ESET PROTECT** constitue le poste de commandement de la solution. Elle offre une vue unifiée sur l'ensemble des endpoints protégés, des incidents détectés et des vulnérabilités identifiées sur le parc bancaire. C'est depuis cette interface que les administrateurs sécurité de la BNM pilotent au quotidien la protection de l'infrastructure.

7.4.1 Tableau de bord et statistiques globales

Le tableau de bord principal d'ESET PROTECT centralise les indicateurs clés de la sécurité du parc. L'onglet *ESET Inspect*, dédié aux détections comportementales avancées, présente une vue synthétique des menaces classées par niveau de gravité (informations, avertissement, critique), ainsi qu'une évolution temporelle des détections sur les sept derniers jours. Un classement des dix ordinateurs les plus exposés permet de prioriser rapi-

dement les interventions, tandis qu'un diagramme circulaire illustre la répartition globale des postes selon la criticité des alertes.

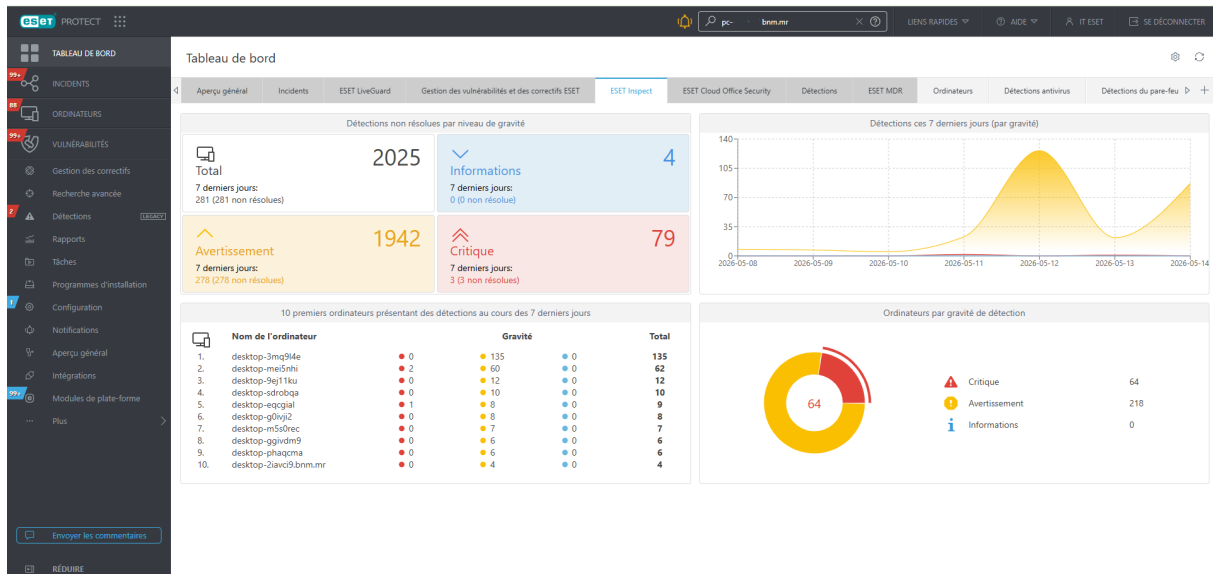


FIGURE 7.9 – Tableau de bord ESET PROTECT : vue ESET Inspect et statistiques de détection

Cette vue permet à l'équipe sécurité d'identifier instantanément les tendances anormales : un pic de détections critiques sur une période donnée, un poste particulièrement ciblé ou une dérive globale du niveau de menace sur le parc.

7.4.2 Vue détaillée d'un poste supervisé

Pour chaque ordinateur enrôlé dans la console, ESET PROTECT propose une fiche détaillée regroupant l'ensemble des informations techniques et sécuritaires. Cette vue affiche notamment le nom complet du poste (FQDN), son adresse IP, le groupe d'appartenance, les politiques de sécurité appliquées, l'état des modules ESET installés ainsi que les indicateurs de santé en temps réel : nombre d'alertes actives, d'incidents, d'indicateurs de compromission et de vulnérabilités identifiées.

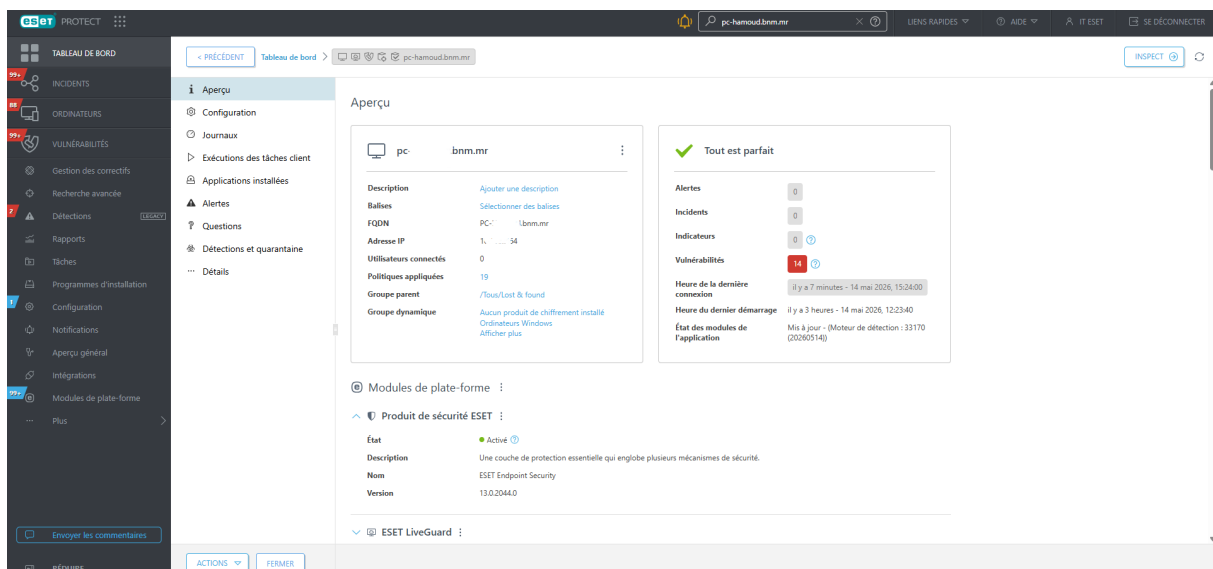


FIGURE 7.10 – Fiche détaillée d'un poste supervisé depuis la console ESET PROTECT

Cette granularité permet de mener des investigations ciblées, de vérifier qu'un poste est correctement protégé et à jour, et d'accéder rapidement aux journaux, aux tâches en cours d'exécution et aux applications installées sur la machine.

7.4.3 Notifications automatiques par courriel

ESET PROTECT intègre un système de **notifications automatiques** qui alerte les administrateurs par courriel lors d'événements importants. Ces notifications couvrent un large éventail de situations : connexion d'un nouveau poste au parc, détection d'une menace critique, déconnexion prolongée d'un agent, expiration d'une licence, etc. Cette automatisation permet aux équipes de réagir rapidement sans nécessiter une surveillance continue de la console.



FIGURE 7.11 – Notification automatique reçue lors du raccordement d'un nouveau poste au parc

7.5 Bilan de cette immersion

L'étude de la solution ESET XDR et le déploiement sur plus de quatre-vingts postes de la banque ont constitué une expérience particulièrement formatrice. Cette intervention a permis non seulement d'acquérir une maîtrise opérationnelle d'une solution de cybersécurité de référence dans le secteur bancaire, mais aussi de comprendre l'importance de la **défense en profondeur** : un pare-feu périmétrique tel que FortiGate, un système IDS/IPS comme Suricata, et une solution XDR sur les endpoints ne sont pas concurrents mais complémentaires, chacun couvrant une couche spécifique de la chaîne d'attaque. Cette vision multicouche, observée concrètement à la BNM, constitue l'un des enseignements majeurs retirés de ce stage.

Conclusion Générale

Bilan du projet

Ce projet de fin d'études, réalisé au sein de la **BNM**, a permis de concevoir, de déployer et de valider une solution complète de sécurité réseau basée sur les technologies IDS/IPS, tout en bénéficiant d'une immersion professionnelle riche au sein de la Direction des Systèmes d'Information. L'ensemble des objectifs initiaux a été atteint et même dépassé, grâce à la double dimension du stage : un volet technique de laboratoire et un volet opérationnel en production.

Sur le plan technique, une infrastructure réseau virtualisée complète a été déployée sous Oracle VirtualBox, reproduisant fidèlement l'architecture d'un environnement bancaire. Le pare-feu **pfSense** a été configuré de bout en bout, incluant le routage, la translation d'adresses (NAT), les règles de filtrage et la gestion des passerelles. Un domaine **Active Directory** `monlab.local` a été mis en place avec deux contrôleurs de domaine (SRV-AD1 et SRV-AD2) assurant la redondance, ainsi que les services DHCP, DNS et un serveur FTP. Les postes clients Windows 10 et Debian 12 ont été joints au domaine et testés avec succès. Un tunnel **OpenVPN** sécurisé, reposant sur le chiffrement AES-256-GCM, l'intégrité SHA256 et l'échange Diffie-Hellman 2048 bits, a été configuré pour garantir un accès distant fiable au réseau interne. Enfin, le moteur **Suricata** a été déployé en mode IDS/IPS avec plus de 30 000 signatures Emerging Threats, et des tests d'intrusion exhaustifs menés depuis Kali Linux (scans Nmap SYN, XMAS, FIN, NULL et agressifs, brute force Hydra sur FTP, tests de détection HTTP) ont validé l'efficacité de la solution, l'ensemble des attaques détectées ayant été bloquées en mode IPS.

Au-delà du laboratoire virtualisé, le stage à la **Banque Nationale de Mauritanie** a constitué une véritable immersion dans l'environnement de production d'un établissement bancaire, permettant d'observer et de contribuer aux solutions de sécurité réellement déployées. Une étude du pare-feu **FortiGate** en production a été menée, à travers l'analyse de sa configuration, de ses règles de filtrage et de ses politiques de sécurité, ce qui a permis de comprendre concrètement le rôle d'un pare-feu de nouvelle génération (NGFW) dans la protection du périmètre d'un système d'information bancaire. La solution **XDR ESET** a également fait l'objet d'une étude détaillée, grâce à un contact direct et privilégié avec l'équipe ESET, qui a permis d'appréhender les mécanismes avancés de cette plateforme : détection comportementale des intrusions, identification et blocage des malwares et virus, génération d'alertes en temps réel et isolation automatique des machines compromises afin d'endiguer la propagation des menaces sur le réseau interne.

Cette expérience s'est également traduite par une **intervention concrète sur le terrain**, à travers le déploiement de l'agent XDR ESET sur **plus de quatre-vingts postes** de la banque. Cette mission a inclus l'installation et la configuration de l'agent, la validation de son bon fonctionnement, ainsi que la résolution de problèmes annexes liés au DNS et à la connectivité réseau rencontrés sur certains postes. Cette intervention a permis d'acquérir une compréhension globale de l'architecture réseau bancaire et des mécanismes de sécurité multicouches déployés pour protéger les systèmes d'information critiques.

Cette double expérience, alliant la conception d'un environnement IDS/IPS de bout en bout en laboratoire et une immersion opérationnelle aux côtés des équipes de sécurité de la BNM, a permis de relier de manière concrète les concepts théoriques aux pratiques réelles du secteur bancaire. Le stage s'est déroulé dans un cadre particulièrement favorable, marqué par des équipes organisées, collaboratives et disponibles, qui ont partagé sans réserve leur expertise et favorisé un apprentissage rapide et structuré. Cet environnement humain et professionnel a constitué un atout majeur pour la réussite de ce projet et pour la consolidation d'une vision globale de la cybersécurité bancaire.

Compétences acquises

Ce stage a été l'occasion d'acquérir des compétences techniques pointues en cybersécurité : administration de pare-feux de nouvelle génération (NGFW), gestion d'un annuaire Active Directory dans un contexte multiplateforme, configuration VPN, sécurisation des endpoints par **XDR(ESET)** et analyse des menaces réseau. La confrontation avec des problèmes réels (boucle de routage, synchronisation Kerberos, configuration pfSense) a renforcé les capacités de diagnostic et de résolution de problèmes.

Perspectives

Ce projet constitue une base solide pour des développements futurs : intégration d'un SIEM pour la corrélation des alertes, déploiement de sondes IDS sur d'autres segments du réseau bancaire, automatisation de la réponse aux incidents (SOAR), et mise en conformité avec les standards de sécurité financière (PCI-DSS).

**“La cybersécurité est un marathon, pas un sprint.
Détecter aujourd'hui pour protéger demain.”**

Annexe A

Checklist Complète du Projet

TABLE A.1 – État d'avancement du projet

Élément	Statut
pfSense installé et configuré (Firewall + NAT + Routage)	✓ FAIT
Problème de routage résolu définitivement	✓ FAIT
AD Principal (SRV-AD1) + DNS + FTP	✓ FAIT
AD Secondaire (SRV-AD2) + DHCP	✓ FAIT
4 utilisateurs AD + 1 utilisateur VPN créés	✓ FAIT
Client Windows 10 joint au domaine	✓ FAIT
Debian 12 jointe au domaine AD	✓ FAIT
Serveur FTP testé (connexion + upload)	✓ FAIT
OpenVPN configuré et testé	✓ FAIT
Suricata IDS/IPS installé et actif	✓ FAIT
Règles Emerging Threats activées	✓ FAIT
Kali Linux installé (machine d'attaque)	✓ FAIT
Tests d'intrusion réalisés (nmap, hydra, curl)	✓ FAIT
Alertes Suricata vérifiées et validées	✓ FAIT
Blocage de toutes les attaques détectées par IPS	✓ FAIT
Rapport PFE	✓ FAIT

Annexe B

Problèmes Rencontrés et Solutions

TABLE B.1 – Problèmes et solutions

Problème	Cause	Solution
Boucle de routage (TTL expired)	Gateway LAN définie comme route par défaut	Suppression LANGW, Default GW = WAN_DHCP
Pas d'Internet sur les serveurs	Forwarders DNS non configurés sur SRV-AD1	Ajout forwarders : 192.168.100.1, 8.8.8.8
Jonction Debian → AD (Preauthentication failed)	Décalage d'heure de 7h entre Debian et AD	<code>ntpdate 192.168.100.3</code>
Alertes Suricata vides dans l'interface	Option Send Alerts to System Log non activée	Activation + Restart Suricata
Kali écran noir au démarrage	Driver graphique vmwgfx incompatible VirtualBox	VBoxSVGA, 3D Acceleration OFF
Kali même IP que pfSense	NAT VirtualBox donne même IP à toutes les VMs	Création du NAT Network pour éviter la confluence des adresses

Annexe C

Technologies Utilisées

TABLE C.1 – Stack technologique du projet

Catégorie	Technologie	Version / Détail
Virtualisation	Oracle VirtualBox	7.1.6
Firewall / Routeur	pfSense CE	2.8.1-RELEASE (FreeBSD)
IDS/IPS	Suricata	Intégré pfSense
Règles de détection	Emerging Threats Open	+30 000 signatures
VPN	OpenVPN	2.6.9 (intégré pfSense)
Active Directory	Windows Server 2019	AD DS, DNS, DHCP, FTP
Serveur FTP	IIS 10 FTP Server	Port 21, auth. AD
Client Windows	Windows 10	64-bit, joint au domaine
Linux	Debian 12 (Bookworm)	Joint au domaine AD
Tests d'attaque	Kali Linux	Nmap 7.93, Hydra 9.5
Auth. Linux/AD	realmd + sssd + Kerberos	krb5-user, adcli
Analyse paquets	Wireshark	Intégré Kali

Bibliographie

- [1] OISF — *Suricata Documentation*. <https://docs.suricata.io/>
- [2] Netgate — *pfSense CE Documentation*. <https://docs.netgate.com/pfsense/en/latest/>
- [3] Proofpoint — *Emerging Threats Open Rules*. <https://rules.emergingthreats.net/>
- [4] Gordon Lyon — *Nmap Network Scanning*. <https://nmap.org/book/>
- [5] OpenVPN Inc. — *OpenVPN Documentation*. <https://openvpn.net/community-resources/>
- [6] Microsoft — *Active Directory Domain Services Overview*. <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/>
- [7] William Stallings — *Network Security Essentials*, 6^e édition, Pearson, 2017.
- [8] RFC 4120 — *The Kerberos Network Authentication Service (V5)*, <https://tools.ietf.org/html/rfc4120>

Annexe D

Attestation et Profile

- ✓ LinkedIn <https://www.linkedin.com/in/mohamed-salem-abdel-wedoud-a7bb9736b/>
- ✓ Github <https://github.com/abdelwedoudmohamedsalem-glitch>



Banque Nationale de Mauritanie
البنك الوطني لموريتانيا

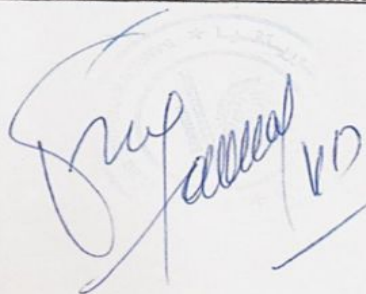
Nouakchott, le 15 Mai 2026

ATTESTATION DE STAGE

Nous soussignés, **BANQUE NATIONALE DE MAURITANIE**, au Capital d'un (1.5000.000.000)MRU, Siège Social Avenue Gemal Abdel Nasser B.P 291 & 614 Nouakchott, Mauritanie attestons par la présente que **Monsieur Mohamed Salem Abdel Wedoud** a effectué un stage academique du 14/04/2026 au 13/05/2026 dans notre insitution.

En foi de quoi la présente attestation lui est délivrée pour servir et valoir ce que de droit.

Departement des Ressources Humaines



المقر شارع جمال عبد الناصر ص ب 291 و 614 شركة مساهمة رأسمالها مليار وخمس مائة مليون اوقية ل ب م
 هاتف : 45 25 12 62 - فاكس : 45 25 33 97 - (222) 45 25 33 97 - مريتبانك
 Société Anonyme au Capital de 1.500.000.000 MRU - Siège Social: Avenue Jamal Abdel Nasser BP. 291 & 614
 Tél : (222) 45 25 12 62 - Télécopie : (222) 45 25 33 97 - ADR MAURITBANK
 Code Swift : BQNM MRRM - E-mail : bnm10@bnm.mr

Rapport de Projet de Fin d'Études

Université de Nouakchott Al Asriya — FST

Mise en œuvre d'une Solution de Sécurité Réseau basé sur IDS/IPS :

— Intégration de Suricata sur pfSense —



*Protéger les systèmes d'information,
c'est protéger les hommes.*

